Privacy Evaluation of the European Digital Identity Wallet's Architecture and Reference Framework

Iván Abellán Álvarez
University of Luxembourg, SnT
Luxembourg, Luxembourg
ivan.abellan@uni.lu

Pol Hölzmer
University of Luxembourg, SnT
Luxembourg, Luxembourg
pol.hoelzmer@uni.lu

Johannes Sedlmeir
University of Luxembourg, SnT
Luxembourg, Luxembourg
johannes.sedlmeir@uni.lu

Abstract

The rise of digital identity wallets promises significant advancements in digital identity management by offering end users a high degree of security and control over data disclosure. However, criticism regarding their privacy guarantees persists, especially when using these identities in strongly regulated processes that require high levels of assurance. In this paper, we present a comprehensive privacy model and analysis of one of the most prominent digital wallets – the European Digital Identity Wallet (EUDIW) – as specified by the Architecture Reference Framework (ARF) and the electronic Identification, Authentication and Trust Services (eIDAS) 2.0 regulation. We employ a suite of qualitative privacy risk assessment methods to systematically map and evaluate information flows in three key use cases. Our systematic evaluation identifies multiple privacy risks – including linkability and excessive data disclosure – and reveals that although the ARF is designed to comply with privacy-by-design principles, the EUDIW's reliance on the OpenID4{VCI, VP} and ISO18013-5 protocols introduces inherent risks to user privacy. We then point to advanced privacy-enhancing technologies (PETs) to address these challenges.

Keywords

Cybersecurity, Data Minimization, European Digital Identity Wallet, Privacy Threat Modeling, Unlinkability

1 Introduction

Digital Identity Wallets (DIWs) promises a secure and privacy-centric approach to digital identity management [66], sustaining the disclosure control of identity holders and expressing their right to privacy, among other principles [2, 94]. The European Union (EU) has decided to leverage this opportunity and is developing the EU Digital Identity Wallet (EUDIW) under the revised eIDAS 2.0 regulation (EU/2024/1183) to provide a standardized, interoperable, and user-centric secure digital identity solution across Member States (MSs) [46, 49]. As such, the EU creates an important case in the evolution of identity systems and is among the pioneers to deploy such a solution on a large scale [89]. Unlike traditional digital identity infrastructures, which often rely on centralized databases controlled by national authorities or private identity providers, the EUDIW applies a wallet-based approach that grants users a high degree of portability and disclosure control [36, 48].

Compared to the federation of heterogeneous state-issued national electronic Identification (eID) systems notified under the eIDAS 1.0 regulation (EU/910/2014) [47], the EUDIW increases the degree of technical harmonization and extends the wallet's functionality to offline interactions, qualified electronic signatures, and attribute disclosure. However, with the EUDIW emerging as a large-scale ecosystem for (legal) identity management on an unprecedented scale and scope, examining its privacy guarantees is paramount [66]. Digital identity systems inherently create risks such as, but not limited to, linkability, identifiability, and surveillance [41, 71], and manifestations of poor data protection may reduce end users' willingness to adopt. The EUDIW promises a technology-agnostic, user-centric, and privacy-by-design model, which manifests not only in the regulation but also in the corresponding Architecture and Reference Framework (ARF) that emphasizes the data minimization principle imposed by the General Data Protection Regulation (GDPR) (EU/2016/679). However, without a rigorous technical specification and analysis, even a system that is designed to be privacy-oriented poses risks of enabling mass surveillance and ultimately undermining user sovereignty [71, 75, 111].

Unlike other DIWs, the EUDIW under eIDAS 2.0 is (in theory) technology-agnostic. At the same time, it must accommodate diverse stakeholder requirements that influence its technical design, which is reflected in the ARF. The ARF serves as the technical specification and is bound to eIDAS 2.0 via the implementing regulation (EU) 2024/2977 [50]. Compliance with other legal frameworks, such as GDPR [54] and the OECD privacy principles [82], further strengthens the positioning of the EUDIW as a privacy-by-design solution. However, diverging interpretations of privacy affect the adoption of protective measures [21, 98] and can lead to tensions between principles and real-world constraints [92].

These tensions highlight the need for structured assessments, which cover quantitative and qualitative methods, to evaluate privacy risks effectively [39, 98, 105]. Such assessments are heavily influenced by the underlying evaluation framework and the specific reference system [83]. As such, they require a comprehensive approach that considers theoretical privacy models and their practical implementation within regulatory and technical constraints.

In this work, we contribute the following:

- We conduct a structured privacy evaluation of the EUDIW's ARF (v1.5) [48] using the LINDDUN threat modeling framework [39] for three key use cases: (1) attestation issuance, (2) attestation presentation in remote settings, and (3) attestation presentation in offline settings.
- We identify and categorize potential privacy threat scenarios from the perspectives of human-centric expectations and compliance-driven requirements.
- We develop a detailed mapping from privacy threats to potential harms following Solove's taxonomy [98].
- We offer actionable insights for risk mitigation by discussing the potential of PETs, such as ZKPs, to hold up to the privacy promises of the EUDIW.

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

The paper is structured as follows: We first provide an overview of related work on privacy-related aspects in digital identity wallets in Section 2. Subsequently, we present our privacy model of the EUDIW by outlining the target system, specified by means of the ARF in Section 3 and the corresponding privacy-specific analysis in Section 4. Section 5 then surveys a set of Privacy-Enhancing Technologies that could tighten the privacy gap of the EUDIW. Section 6 discusses our main findings, and Section 7 concludes.

2 Background & Related Work

2.1 Digital Identity Wallets

Digital identity solutions have evolved from centralized databases and federated identity systems to more decentralized and user-centric approaches [61]. The popularity of wallet-based identity solutions grew following the widespread adoption of blockchain technology [7]. Multiple blockchain-based ecosystems employ digital wallets as interfaces for managing private keys, authorizing transactions, and verifying identity-related assertions while preserving privacy and reducing dependence on centralized entities [8, 69, 88, 93].

Building on these developments, the Self-Sovereign Identity (SSI) paradigm [2] extends digital wallets to handle more complex identity data, such as verifiable attestations [101]. Wallets offer a comprehensive set of functionalities, allowing users effective data management, portability, and disclosure control in an ecosystem of compatible relying parties [66, 94]. However, these systems also introduce new challenges related to governance, scalability, and regulatory compliance, particularly in environments requiring high levels of trust and legal certainty.

The architecture of DIWs, including the EUDIW, revolves around three core processes: issuance, verification, and revocation [17]. Trusted entities issue cryptographically signed digital attestations of attributes containing personal data. Verification allows relying parties to assert trust in the validity, integrity, and authenticity of attestations presented by users. In addition, revocation mechanisms ensure that compromised or expired attestations can be invalidated through registries or advanced cryptographic techniques, such as accumulators [22].

In the eIDAS 2.0 framework, DIWs provide a legally recognized and interoperable method for electronic identification, authentication, and signatures across the EU. The EUDIW supports multiple high-assurance use cases such as eGovernment services, electronic Know Your Customer (eKYC), mobile Driver's License (mDL), embedded SIM (eSIM) registration, and prescriptions [89]. Unlike traditional identity systems requiring extensive data sharing, the EUDIW is supposed to prioritize data minimization and user control, aligning eIDAS with GDPR principles.

A key characteristic of DIWs is their emphasis on user data sovereignty [42], as attestations and cryptographic keys are stored locally and under the respective end user's control, rather than being maintained in centralized databases. By pushing wallet-based digital identity solutions to broad adoption within the eIDAS 2.0 framework, the EU seeks to address data sovereignty shortcomings in digital identity management while ensuring a high level of trust, security, and interoperability.

The EUDIW shall address a diverse collection of online and offline use cases, which require the EUDIW to support a wide range of electronic functionalities, including identification, authentication, and data-sharing practices of personal information in compliance with EU regulations. In addition, it shall be interoperable and acceptable by all MSs, which leads to additional complexity in designing a system that accounts for all dimensions. Concretely, the EUDIW has to accommodate technical, organizational, and regulatory requirements. Consequently, finding the right balance between openness and harmonization is difficult. The current technical specification of the EUDIW, called the Architecture and Reference Framework (ARF), aims to strike this balance [30–32, 48, 54]. At the same time, eIDAS 2.0 has recognized the importance of safeguarding end users' privacy by technical means, integrating the following statements.

eIDAS 2.0 Regulation (EU/2024/1183) (Extracts)

Article 5a(16)

The technical framework of the EUDIW shall:

(a) not allow providers of electronic attestation of attributes or any other party, after the issuance of the attestation of attributes, to obtain data that allows transactions or user behaviour to be tracked, linked or correlated, or knowledge of transactions or user behaviour to be otherwise obtained, unless explicitly authorised by the user;

(b) enable privacy-enhancing technologies which ensure unlinkability, where the attestation of attributes does not require the identification of the user.

Recital[1]

(14) Member States should integrate different privacy-enhancing technologies, such as zero-knowledge proofs, into the EUDIW. Those cryptographic methods should allow a relaying party to validate whether a given statement based on the person's identification data and attestation of attributes is true, without revealing any data on which that statement is based, thereby preserving the privacy of the user.

2.2 Privacy Metrics and Frameworks

Informational privacy is defined as the protection of personal data from unnecessary collection, exposure, or misuse, ensuring that individuals can use a service without revealing more information than is required for its intended function [29]. As such, it is closely related to the concept of informational self-determination [64]. While the EUDIW ecosystem heavily relies on a regulatory framework that implements privacy safeguards by means such as the GDPR, eIDAS 2.0 emphasizes that the EUDIW should implement privacy by design and default, i.e., enforce disclosure control and data minimization through thoughtful algorithms and cryptographic mechanisms [25]. Privacy guarantees in the EUDIW emerge from the combination of regulatory requirements, system specification, and technical implementation. The EUDIW operates within a regulatory landscape that shapes privacy through compliance requirements yet permits the adoption of solutions that do not provide the claimed result.

[1]Note that recitals are not legally binding and are intended to be used in case of ambiguity or dispute regarding an article's intended meaning or to exemplify a case.

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

While security by design focuses on safeguarding the system's technical properties, privacy is inherently a human-centric concept, addressing how individuals' data is protected within societal and technological contexts [98].

Privacy by design emerges as a core concept in privacy-first methodologies [25]. Although privacy-by-design principles are emphasized frequently in regulatory texts, their practical enforcement depends on the interpretation and implementation of both legal text and technical standards [85]. The GDPR defines legal obligations related to personal data protection, including data minimization, purpose limitation, and user control, while eIDAS 2.0 introduces additional requirements for secure digital identity management across EU MSs. Broader international principles, such as the OECD Privacy Guidelines, provide high-level guidance but do not prescribe concrete technical safeguards [82]. The practical realization of privacy in identity systems thus depends on the extent to which these regulations translate into technical measures and operational policies [48].

Generally, the key privacy risks in identity management are linkability, identifiability, non-repudiation, detectability, and information disclosure [39, 87]. Linkability refers to the ability to correlate different interactions, potentially enabling tracking and profiling. Identifiability assesses whether a user can be uniquely distinguished based on shared attributes. Non-repudiation, while critical for accountability, can conflict with privacy by making digital interactions permanently attributable. Detectability (or observability) indicates whether an interaction can be inferred even if its content remains hidden. Information disclosure measures unintended exposure of data beyond its intended scope. These risks highlight the gap between privacy as a legal requirement and its practical enforcement within identity ecosystems like the EUDIW.

In February 2024, the at that time latest version 1.5 of the ARF[2] added a section that briefly surveys risks and mitigation measures related to user privacy. However, this analysis was incomplete. For instance, it only describes the Relying Party (RP) and Attestation Provider (AP) linkability. To account for the lack of a definition of (un)linkability as required per eIDAS 2.0 Article 5a(16), we draw on the ISO/IEC 27551:2021 standard [56], which defines a comprehensive framework for unlinkability in attribute-based authentication, addressing various threats to privacy. It outlines multiple notions of (un)linkability to protect users from tracking by different adversaries, arguably the most critical risk to privacy. In this context, likability is pictured as a multifaceted concept [56], encompassing several dimensions that play a crucial role in our interactions and perceptions, including:

Passive outsider (PO-U): External observers passively monitor communications and link users across multiple interactions.

Active outsider (AO-U): External adversaries actively manipulate or inject network traffic to correlate user activities.

RP-U: Relying parties (RPs) can link a user's repeated visits, revealing interactions with services.

AP-U: Attribute providers (APs) can track user authentication requests, enabling profiling based on issued attestations.

RP+AP-U: Collusion between RPs and APs can link a user's activities across different services.

AP-RP: Relying parties can infer patterns about users based on their interactions with attribute providers.

AP-RP+U: Attribute providers and relying parties can correlate users across multiple interactions.

RP+RP'-U: A set of colluding relying parties can link a user's activities across different services.

2.3 Existing Research on Privacy in the EUDIW

As discussed above, the ARF raises questions about privacy compliance, technical feasibility, and societal implications of the EUDIW. The European Commission (EC)'s initial assessment of the EUDIW in [44] outlines various security and privacy risks but does not perform a rigorous and complete evaluation of privacy-specific challenges [45]. To gather the full context and related work, we conducted a preliminary systematic literature review (SLR).

The SLR followed the PRISMA guidelines [78], encompassing identification, screening, eligibility assessment, and inclusion phases. Using the search string *("[European, EU] Digital Identity [Wallet]" OR "[EU]DI[W]") AND ("privacy" OR "data protection")*, we queried a broad set of databases and libraries, including the ACM Digital Library, AIS eLibrary, Emerald, IEEE Xplore, ScienceDirect, and Springer. To exhaust the results, we also searched ArXiv, Google Scholar, Dimensions.ai, and Elicit.Figure 1 features the systematic literature review (SLR) flowchart, outlining the number of results in every step. We first identified 333 records and removed 69 duplicates. We then screened the titles and abstracts of the remaining 261 papers. Based on inclusion criteria such as relevance to EUDIW privacy issues, we considered 34 out of these records eligible for the full-text analysis. Ultimately, we considered only 10 publications as directly relevant to our study of privacy risks and corresponding regulatory gaps and technical solutions for the EUDIW. This highlights especially the limited availability of academic literature addressing privacy in DIWs, underscoring the need for further research in this area.

Baum et al. [9] criticize the EUDIW's ARF, arguing that it fails to achieve unlinkability. They recommend the adoption of anonymous credentials [23] to address privacy risks while ensuring compliance with regulatory requirements. Others, such as [5, 14, 93], similarly advocate for specific Privacy-Enhancing Technologies (PETs) [79], such as Zero-Knowledge Proofs (ZKPs), to ensure compliance with the GDPR's data minimization principles.

Degen and Teubner [36] explore tensions between interoperability, standardization, and privacy in the public-private collaborations that shape the EUDIW's development. They emphasize the need for a technology-neutral framework but acknowledge the challenges in deciding whether the ARF should mandate or exclude specific technologies, such as ZKPs. Ansaroudi et al. [3] categorizes both functional and non-functional requirements for digital wallets, stressing the importance of user-centric design and technological adaptability within the scope of eIDAS 2.0.

The societal implications of digital identity systems are underscored by Mattei et al. [77], who argue for a broader understanding of identity beyond its administrative functions. García-Rodríguez et al. [59] expand on this perspective, proposing distributed identity

[2]Permalink: https://github.com/eu-digital-identity-wallet/eudi-doc-architecture-and-reference-framework/blob/bb81137d4b0f21bbf077fd85a90de265742a9131/docs/architecture-and-reference-framework-main.md

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

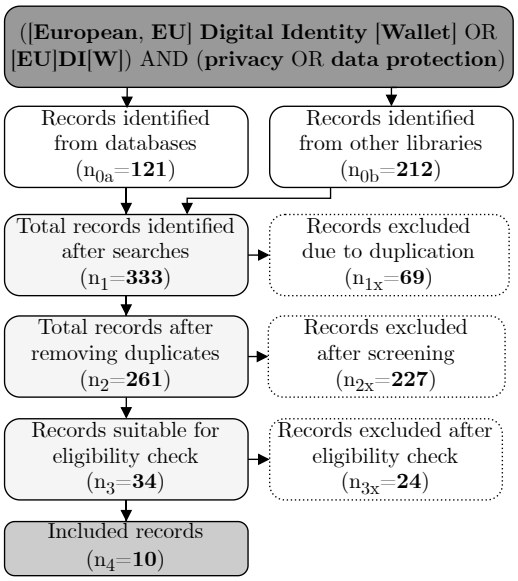


Figure 1: PRISMA reporting flowchart following [78].

frameworks that accommodate flexible privacy mechanisms tailored to societal needs. Teuschel et al. [104] explore user interfaces for DIWs, identifying trade-offs between usability and privacy.

From a technical standpoint, Veseli et al. [107] demonstrate the application of privacy threat modeling, specifically the LINDDUN framework, for a cloud-based identity wallet platform. Larsen et al. [69] focus on achieving high assurance levels in privacy-oriented systems through cryptographic methods, emphasizing the role of secure attestations in balancing privacy and scalability. Slamanig [96] contrasts theoretical guarantees of privacy-preserving authentication methods with the practical challenges of implementing such solutions in the EUDIW ecosystem.

Finally, Marco et al. [76] and Lepore et al. [70] analyze how eIDAS 2.0 aligns with alternative digital trust frameworks, such as Trust over IP [34]. They stress the importance of aligning technical specifications with user trust and regulatory compliance, particularly as the EUDIW aims to support high-assurance use cases like eGovernment services, eKYC, and eSIM registration that were not considered in the roots of SSI [94].

3 Privacy Modeling Method

Given that the European Commission drives the development of the ARF, which serves as the technical specification for an eIDAS 2.0-compliant EUDIW, and the corresponding Reference Implementation (RI)[3], we establish our privacy model and analysis for the EUDIW on the ARF. In doing so, we employ a structured mixed-methods approach, including privacy threat modeling and a privacy risk assessment [108]. As privacy is a multifaceted concept, subject to diverse interpretations depending on legal and contextual factors [98], it requires a structured approach to identifying and addressing risks, as otherwise privacy remains an ambiguous and poorly understood aspect of system design. To address this ambiguity, privacy threat modeling frameworks have emerged as effective tools for systematically analyzing and mitigating privacy risks across domains [74, 107].

We ground our privacy threat model on the LINDDUN framework [39]. LINDDUN has become a prominent privacy threat modeling framework owing to its comprehensive perspective on privacy risks [108, 110], and has been successfully employed before to evaluate the design of critical identity systems [10, 91, 107]. The LINDDUN framework provides a systematic approach for privacy analysis that is complemented by a categorization of well-documented privacy threats that can pose a risk to system users [106] and a set of attack trees per privacy threat describing corresponding potential realization paths [39]. LINDDUN is an acronym composed of the set of the following privacy threats: *Linkability*, *identifiability*, *non-repudiation*, *information disclosure*, *detectability*, *user unawareness*, and *policy non-compliance*. We complement this with a privacy risk assessment using an argumentation-based method to illustrate the most significant privacy threats [1], contrary to privacy impact assessments, which account for data protection compliance [83].

Although this study references legal texts, such as the eIDAS 2.0 Regulation (EU/2024/1186) [53, 55], related implementing acts [31], and the GDPR (EU/2016/679) [54], it does not aim to provide a legal assessment or interpretation of compliance. Instead, we focus on analyzing the ARF specification in terms of its adherence to privacy-by-design principles and evaluating its ability to meet technical privacy requirements. While our approach is informed by legal principles (e.g., data minimization, purpose limitation, user consent, Art. 5(b)(c) and Art. 6a [54]) alongside their practical implications (e.g., implementing consent mechanisms or secure data storage), we do not attempt to replace the expertise of legal professionals or regulatory authorities in determining compliance. Consequently, we have deliberately excluded the threats of *user unawareness* and *regulatory non-compliance* from the evaluation model. While user awareness is an integral aspect of privacy risks, issues such as informed consent introduce moral dilemmas [21, 99] and often depend on contexts beyond purely technical evaluations. Similarly, *regulatory non-compliance* hinges on the legal interpretation of whether a system aligns with the applicable regulatory framework.

The LINDDUN framework consists of six stages for conducting a privacy analysis and a final privacy elicitation. First, the LINDDUN framework requires the creation of a data flow diagram (Section 4.1). Next, the privacy analysis (Section 4.2) involves mapping the categorized set of privacy threats to relevant elements in the target model (Section 4.2). Third, we identify and enumerate privacy threat cases based on use case scenarios and system design assumptions (see Section 4.3). Fourth, we complement the analysis with a risk assessment approach, using Solove's privacy taxonomy [98], to analyze the significance of every enumerated privacy threat case (Section 4.4). In Section 5, we then outline appropriate PETs to mitigate the privacy threats identified before.

4 Privacy model

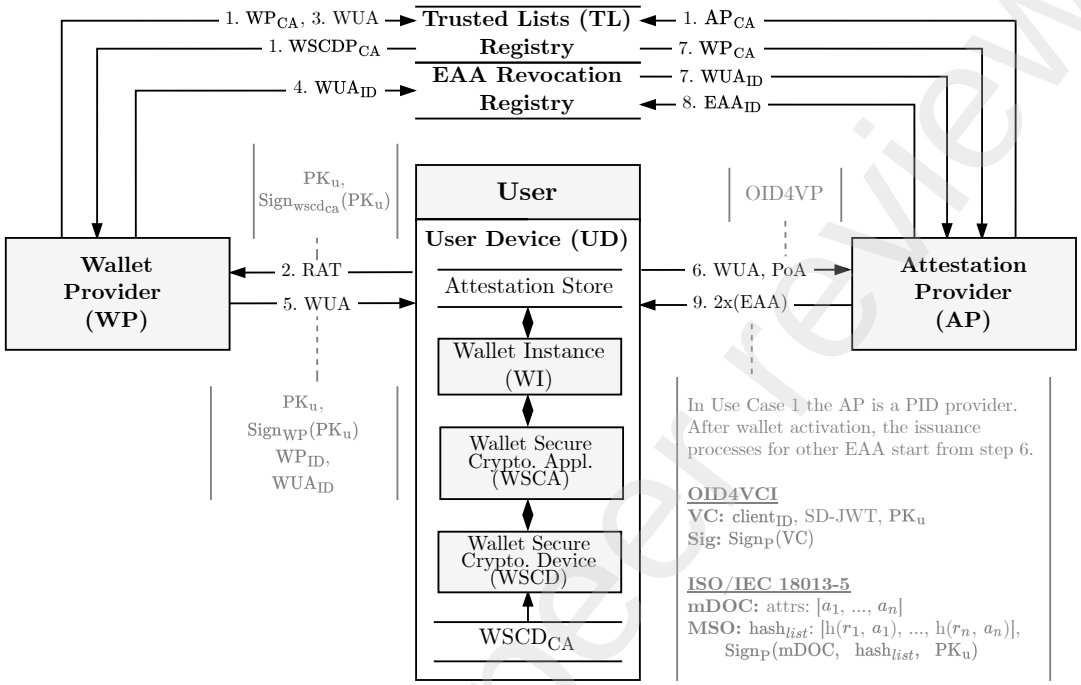
4.1 Information Flow Modeling

Establishing a formal model for the EUDIW is crucial for ensuring clarity, consistency, and comparability across its diverse use

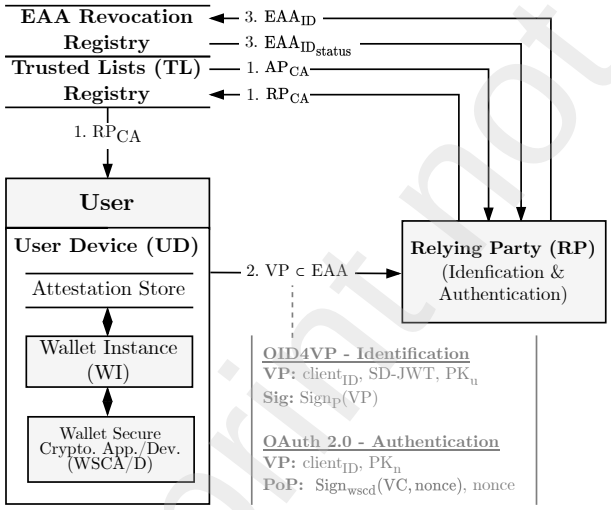
[3]Permalink: https://github.com/eu-digital-identity-wallet/.github/blob/\960f9188a05266c9367a721150f68c687281396e/profile/reference-implementation.md

Preprint not peer reviewed

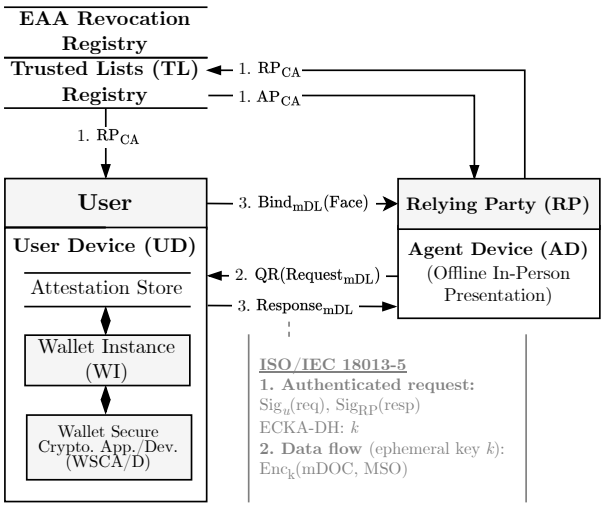
This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779



(a) Issuance of PID in a remote flow for wallet activation



(b) Presentation of EAA in a remote flow for online authentication



(c) Presentation of mDL in a proximity flow for supervised offline authentication

Figure 2: Data flow diagrams of EUDIW use cases.

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

cases that span multiple domains, each with distinct operational, technical, and regulatory requirements. A formal model provides a common foundation to set boundaries and to understand how different components interact and compare within various contexts. Interaction modalities, such as proximity (offline) versus remote (online) or supervised versus unsupervised [48], greatly affect the underlying technologies, threat landscape, and trust relationships. Similarly, actions such as issuance, verification, or revocation involve context-dependent privacy considerations. Consequently, identifying and mitigating privacy risks for the EUDIW necessitates a decomposition and formalization of involved components in the corresponding ecosystem. To address this complexity, we introduce a formal model for the EUDIW, focusing on applications with a high Level of Assurance (LoA) and scenarios defined in the POTENTIAL Large Scale Pilot (LSP) [89]:

$$
\begin{aligned}
\text{EUDIW} &:= [\text{Asset}]\ [\text{Action}]\ [\text{Flow}]\ [\text{Scenario}] \\
\text{Asset} &:= \text{PID} \mid \text{QEAA} \mid \text{EAA} \mid s\text{PuB-EAA} \\
\text{Action} &:= \text{issuance} \mid \text{presentation} \mid \text{verification} \mid \text{revocation} \\
\text{Flow} &:= \text{proximity (supervised} \mid \text{unsupervised)} \\
&\quad \mid \text{remote(cross-device} \mid \text{same-device)} \\
\text{Scenario} &:= \text{eGOV} \mid \text{eKYC} \mid \text{mDL} \mid \text{eSIM} \mid \text{ePrescription} \\
&\quad \mid \text{QES(wallet-centric} \mid \text{QTSP-centric)}
\end{aligned}
$$

The formal model defines the EUDIW as a generalized composite construct consisting of four distinct components: assets, actions, flows, and scenarios. Assets represent an instance of a specific type of digital attestation (i.e., Electronic Attestation of Attributes (EAA)), which may take, despite being technically almost identical, several forms with different legal meanings. In this sense, a Qualified Electronic Attestation of Attributes (QEAA) must be issued by a Qualified Trust Service Provider (QTSP), similar to a PuB-EAA, which can be issued by any public entity. However, the most critical is the Person Identification Data (PID), which is similar to an eID. Note that ultimately, PID, QEAA, PuB-EAA $\subset$ EAA [48, 55]. The action component delineates the lifecycle-related processes applied to assets, encompassing issuance, presentation, verification, and revocation [17]. The flow component characterizes the interaction modality of assets, which can occur either across devices or on the same device. Finally, the scenario anchors the model in real-world applications with LoA high by identifying various operational scenarios, such as eGOV, eKYC, mDL, eSIM, ePrescription, and Qualified Electronic Signature (QES) [89].

Although the EUDIW aims to define a universal wallet for EU citizens so that it encompasses a myriad of use cases, we restrict the system modeling to a subset of three of the most important with diverse requirements, which we cover in the following sections. For each, we model the information flow of data, following a structured approach that circulates through the lifecycle of several of the use cases foreseen by the ARF [38, 48]. Unfortunately, it is not possible to cover every permutation of the model. Therefore, we do not cover the rather unique scenario of QES, which is procedurally quite different from all other scenarios, leaning on the Cloud Signature Consortium (CSC) specification [27]. We define three concrete use cases based on the formal model in the following.

Use Case 1, Figure 2(a): Issuance of PID in a Remote Flow for Wallet Activation. The activation of a EUDIW (See ARFs section 6.5.3) involves a coordinated process among several qualified entities to ensure both the wallet's validity and its security. The process begins with the user installing the EUDIW application provided by a certified Wallet Provider (WP), listed in a public Trust List (TL) registry. Once installed, the wallet must acquire a Wallet Unit Attestation (WUA) from the WP for device-binding to enter an operational state and must then obtain PID from a nationally recognized PID provider for user-binding. The PID and WUA are securely stored within the wallet for future presentations, forming an active Wallet Unit (WU), bound to the device and user. The PID provider must verify the user's identity before starting the issuance via any authentication means in compliance with eIDASs LoA high.

The security guarantees, particularly for device binding, are based on the Wallet Secure Cryptographic Device (WSCD) – a certified cryptographic device that protects sensitive materials such as private keys – and a Wallet Secure Cryptographic Application (WSCA), which executes critical operations in a Trusted Execution Environment (TEE). To ensure that the wallet software is installed on a secure and supported device that provides a WSCD, the WP collects device information and issues an WUA that is linked to the user's wallet key pair to achieve device-binding. The WUA serves two primary purposes: (1) it confirms the wallet's active status, and (2) it certifies the WU by validating the user's key pair using the WSCD.

To acquire PID from PID Providers, the user must be identified, authenticated, and demonstrate control over both the certified key pair and an active WU (i.e., the WUA) for holder-binding. This process creates a verifiable link between the WUA and PID. The PID is issued both in the W3C (VC) [101] and ISO18013-5 (mDOC) formats [57], with their revocation status managed via a public revocation registry. Overall, this activation process is a prerequisite for using the EUDIW, ensuring that the wallet is securely linked to the user's verified identity and enabling trusted interactions.

Use Case 2, Figure 2(b): Presentation of EAA in a Remote Flow for Online Authentication. Here, users can leverage an active EUDIW instance to identify and authenticate (see ARFs 2.2 and A4.2) themselves across various online services, ensuring compliance with differing levels of assurance. Any presentation begins with an Relying Party (RP) requesting to disclose full attestations, specific attributes, or a combination of multiple attestations. This process is primarily designed to work with the OpenID4 (or OID4) protocol [103], but also ISO18013-5 [57]. For LoA low, it is also possible to use self-signed pseudonymous identities via the Self-Issued OpenID Provider (SIOP) protocol v2 [84] and combined presentations, but this is out-of-scope for this work. As per use case, authentication may occur in two ways with varying levels of data disclosure: (1) authentication-only, where the user's wallet proves possession of a certified key pair (i.e., WUA), establishing a link with a cryptographic device (e.g., WSCD), and (2) attribute disclosure, where the user consents to sharing specific attributes (e.g., for authorization).

In any case, legitimate RPs must obtain a Relying Party Access Certificate (RPAC) [30, 31], certifying their registration under a trusted body within their respective MS, before requesting any data; otherwise, the wallet declines the request automatically. The RPAC legitimizes the RP's keys and certifies which type of credentials the RP is allowed to request (e.g., not every RP can request

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

PID). Before any data is shared, the wallet shows the requested attributes to the user for review and requires explicit user consent and authentication (e.g., PIN or biometrics). Once granted, the wallet transmits the approved attributes to the RP in an end-to-end encrypted channel, completing the authentication process. Generally, this use case can be done in a same- or cross-device flow, with minor adaptations in the process. In a cross-device scenario, users can access a service on a non-wallet device (e.g., desktop PC). In this flow, the wallet is not triggered via a deep link but instead embedded into a QR code for the wallet device to scan and initiate the presentation. Finally, the RP verifies the Verifiable Presentation (VP)'s authenticity, integrity, and validity before providing the requested service.

Use Case 3, Figure 2(c): Presentation of mDL in a Proximity Flow for Supervised Offline Authentication. The third and final use-case is similar to the one before but relies on proximity communication technologies such as Near-Field Communication (NFC) or Bluetooth Low Energy (BLE) for the presentation of EAAs in peer-to-peer (offline) interaction. For this to work, both the prover (user's wallet) and the verifier must have certified, pre-installed certificates to establish trust, as outlined in ISO18013-5 [57]. Users can create and send authenticated mobile documents (mDOC), which consist of elements that can be retrieved individually (e.g., portrait, family name, issuing authority, etc.). The Mobile Security Object (MSO) is a formatted and serialized attestation type signed by the user wallet key pair composed of the requested attributes. Proximity flows can be unsupervised or supervised: the unsupervised flow typically involves a standalone device for self-services with lower LoA, while the supervised flow includes a human *supervisory agent* (e.g., a law enforcement officer) overseeing the transaction. In the supervised flow, an EAA (e.g., mDL) can be requested with LoA high. mDLs include a signed biometric facial representation (i.e., portrait picture), allowing the agent to ensure holder-binding. Note that in an online proximity flow, the verifier could perform real-time revocation checks, but in an offline proximity flow, the agent would need to omit or pre-download revocation lists. This approach has practical caveats, including the challenge of maintaining up-to-date lists on the verifier's device.

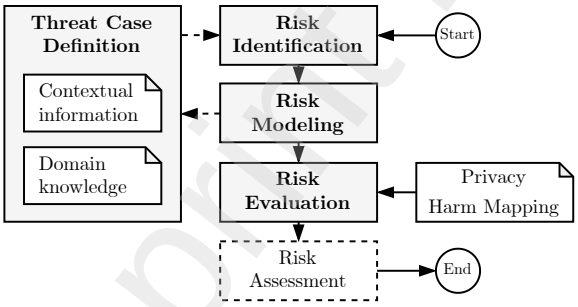


Figure 3: Threat cases modeling method.

4.2 Privacy Threat Mapping

Table 1 presents a detailed mapping of privacy threats to the various components in the ARF [48], based on the system descriptions in Figures 2(a), 2(b), and 2(c). In this table, we organize the analysis according to five key privacy concerns—linkability, identifiability, non-repudiation, detectability/observability, and information disclosure—and illustrate how these threats affect different parts of the system. The table is structured by grouping the components into categories that include core entities, data registries, and data flows. All of these components entail implications for privacy, which arise from various aspects besides the mere high-level application logic, including verifiability, communication protocols, and metadata. Consequently, we also include transactional data, such as the direct disclosure of attributes and metadata related to the used protocols.

Concretely, each listed entity serves as Service Provider (SP) (i.e., data processor), represented by WPs (activation), APs (issuance, revocation), and RPs (presentation, verification). In addition to the entities' data storage, data registries are public ledgers that store trust-related information to verify claims and entity roles. Furthermore, interaction with these SPs is represented as a data flow, including OpenID4{VCI, VP} (verifiable credential issuance and presentation) [73, 103] and ISO18013-5 [57] specifications. Table 1 encapsulates how each component contributes to the privacy threat landscape and lays the foundation for subsequent risk assessments and informs the design of mitigation strategies.

4.3 Threat Cases Enumeration

We focus on a selection of seven unique privacy threat cases for the defined use cases (4.1) and the corresponding privacy threats (4.2). We follow the steps outlined in Figure 3 to model each threat case effectively. A privacy risk assessment (4.4) is integrated into the threat modeling process to underscore potential privacy harms [1, 98]. Threat modeling depends on domain knowledge and the contextual framework in which it operates. Domain knowledge refers to the authors' active involvement in EUDIW working groups and POTENTIAL LSP [89], reflected in the system modeling and the information flow formalization (see Section 4.1 and Figure 2), and the privacy threats mapping (see Table 1). We include in the contextual framework both the EU legislative measures (e.g., ARF design principles [48]; the GDPR [54]; the eIDAS 2.0 [53, 55]; and implementing acts [50, 51, 55]), as well as ethics [80, 92].

Privacy threat and risk modeling are closely related to the privacy assumptions and guarantees outlined in the regulations that guide system design and specifications [95]. To illustrate the difference between various contexts for privacy assessment, we consider two perspectives: viewing privacy as a fundamental right versus viewing it as subject to regulation. For instance, data sharing among consenting parties may not present immediate privacy risks, but even regulated entities can misuse data, posing risks to users [41, 68, 71, 97, 107]. Each threat case is described in textual form according to the general guidelines in [39] and begins with an exhaustive description of the privacy threat, followed by a discussion of how it can be realized and the potential privacy harm it may cause, as noted in [98]. Instead of providing just a summary of threats, we complement the argumentation with relevant literature.

Note that some Identity Management (IdM) processes, such as identification, inherently and explicitly breach privacy-by-design in a generally non-malicious way. This is an intended feature for which we need to identify and/or authenticate the user prior to

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

Table 1: Mapping of privacy threats w.r.t to users. Nomenclature according to [39, 106]

Components	Linkability	Identifiability	Non-repudiation	Detectability/ Observability	Information disclosure
Entity: Wallet Provider (WP)	Any new keypair is linked to WUA (RAT[1])	PK_u as a pseudonym, WUA, WP_{id}, $Sign_{wp}$(WUA)	**Attributable**: PK_u, WSCD's keys[4], Sigs	$PK_u \leftrightarrow$ WUA $\in$ DBs	PoA[2], PK_u, WSCD's keys[4]
Entity: Attestation Provider (AP)	PID and EAA to WUA, PoA[2], oid4-metadata[5]	PID, EAA, PK_u	**Attributable**: WUA, PoA[2], Provider's keys[4]	WUA $\leftrightarrow$ PoA[2]	WUA and PoA[2]
Entity: Relying Party (RP)	PID, (Q)EAA, oid4-metadata[5], PoP[3], PK_u and any derivates	**IDentification**: EAA $\leftrightarrow$ EAA_{revoc_id}, PoP[3] and oid4-metadata[5] **Authentication**: PoP[3] and oid4-metadata[5]	**IDen and AuthN**: EAA $\leftrightarrow$ PK_u, oid4-metadata[5], PoP[3], EAA_{revoc_id}	Session IDs (e.g., oid4-metadata[5]) $\leftrightarrow$ EAA. **Side-effect**: VP $\leftrightarrow$ EAA $\in$ DBs	EAA $\leftrightarrow$ PK_u, oid4-metadata[5], PoP[3]
Data Registry: Revocation list	WUA_{id}, EAA_{revoc_id}	WUA_{id}, EAA_{revoc_id}	WUA_{id}, EAA_{revoc_id}	WUA_{id}, EAA_{revoc_id}	WUA_{id}, EAA_{revoc_id}
Data Registry: Trusted list	WUA, $Sign_{wp}$(WUA)	WUA, $Sign_{wp}$(WUA)	$Sign_{wp}$(WUA)	WUA	WUA, $Sign_{wp}$(WUA)
Data Flow: Wallet-Relying Party	**Remote**: PK_u, Sigs., oid4-metadata[5] $\in$ {VCI,VP} **Proximity**: mDL embedded keys[4]	**Remote**: EAA $\leftrightarrow$ oid4-metadata[5] $\in$ {VCI,VP} **Proximity**: mDL embedded keys[4]	**Remote**: (PoA[2],PoP[3]) $\leftrightarrow$ EAA **Proximity**: mDL embedded keys[4]	**Remote**: VCI/VP **Proximity**: mDL embedded keys[4]	None
Data Flow: Wallet-Wallet Provider	**Remote**: (RAT[1], PoP[3], PoA[2]) $\in$ {VCI,VP}	**Remote**: EAA $\leftrightarrow$ oid4-metadata[5] $\in$ {VCI,VP}	**Remote**: (RAT[1], PoP[3], PoA[2]) $\in$ {VCI,VP}	**Remote**: VCI/VP	None
Data Flow: Wallet-EAA Provider	**Remote**: WUA, EAA_{revoc_id}, oid4-metadata[5] $\in$ {VCI,VP}	**Remote**: EAA $\leftrightarrow$ oid4-metadata[5] $\in$ {VCI,VP}	**Remote**: (PoA[2], PoP[3]) $\leftrightarrow$ EAA	**Remote**: VCI/VP	None

[a] **Notation**: User $u \in U$, Wallet Provider (WP), Wallet Unit Attestation (WUA), Public Key (PK). Note that an EAA in this table accounts for any type of attestation, including PID, QEAA, and Pub-EAA, since those do not differ technically.

[1] Remote Attestation (RAT): Remote evidence verification procedure from a root-of-trust.

[2] Proof of Association (PoA): Certifies both the control of a secret key and the correspondence with a certified device, i.e., $sk_1, pk_1, pk_n$where $n \in N$, $\mathrm{Verf}(Sign_{sk_1}(pk_n), pk_1) = true$.

[3] Proof of Possession (PoP): Certifies the knowledge of a secret key, i.e., $Verf(Sign_{sk}(pk), pk) = true$; secret and public keys sk, pk of entity n.

[4] Authentication keys: embedded certificate keys.

[5] oid4-metadata: Includes required and unique identifiers from the OAuth2.0 framework and OpenID4{VCI, VP} specifications [63, 72, 73, 102, 103]. E.g., "vct", "cnf", "_sd", "client_id", "access_token", "code"

authorization. Therefore, we concentrate on processes within the ARF that circumvent data minimization and potentially result in privacy harm. We refer to identification processes for completeness, but we acknowledge the identification privacy risks resulting from other privacy threats. Linkability, from the introduced threats to privacy, deserves its honorary mention, as specifically highlighted in Art. 5a(16)(b) of the regulation [55], it requires the usage of PETs. However, the term unlinkability is not formally defined in the legal text and, therefore, sparks discussion among experts about what the technical baseline for unlinkability is [56].

Threat Case 1: Linkability of pseudonymous identifiers at RPs in online and offline presentation. During the authentication process, as shown in Figure 2(c), the user's wallet discloses a set of requested attributes with user consent. Additionally, the wallet includes linkable pseudo-identifiers (PK_u, PoP, PoA, WUA_{id}, EAA_{revoc_id}). While the OpenID4{VCI, VP} metadata and PoP may vary between different sessions, they still link information within the same session. However, when users are required to disclose their attributes, they need to reveal the associated PK_u for verification. Furthermore, the PK_u, EAA_{revoc_id}, and the WUA_{id} persist regardless of the session. These pseudo-identifiers, along with the PoA method, are used to identify the session and verify the presentation.

The SD-JWT specification relies on salted hashes of attributes that are signed by the Attestation Provider [102]. While PID is pseudo-anonymized using salted hashes, its fingerprint remains unchanged across all presentations, thus resulting in a unique linkable element. Therefore, there is a risk that such correlatable information is stored [75] and misused to link actions within the same RP, between colluding RPs, or even by RPs colluding with either WPs or APs to track and profile users [41, 45, 68, 71].

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

Although the issuance of attestations could adopt a batched approach to limit linkability risks between colluding RPs [31], this strategy does not prevent attestation providers from colluding with RPs while it may increase both the issuer and holder overhead [9]. The number of attestations that can be issued in a batch is also unclear. Additionally, the EUDIW should accommodate the use of pseudonyms (see [31, 55]); however, the integration of pseudonyms and self-issued identities using SIOP (v2) remains uncertain. Respectively, users may be required to use offline methods for identification and authentication (see Figure 2(c)) but adhering to the ISO18013-5 [57], which includes persistent certificates. As a result, the privacy risks mentioned earlier apply in this context as well.

Moreover, RPs are required to log transactions communicated for an unspecified amount of time (Art. 30 of GDPRs [54]), similarly the user wallet's transaction log (Art 9. of [51]). While these logs are intended for transparency and reporting to data protection authorities, they contain correlatable data, especially if shared or breached. Art 9. [31] even states that "the logs [...] shall be accessible to the wallet provider, [if necessary and consented]."

Misactors: RPs, APs, WPs, supervisory bodies, and ext. actors.

Attack Flow: (Mis)actors (un)intentionally accessing the information within the communication channels or databases containing stored data can correlate the pseudo-identifiers with attributable information within the same database, publicly available, or auxiliary information from other sources.

Trigger: The RP with any other data processor with whom data has been shared, including supervisory bodies. Externals that gain access (un)lawfully. The user in the event of sharing data with supervisory entities.

Preconditions: Access to attributable data and pseudo-identifiers that are linked to each other w.r.t attributable data (e.g., EAA), linkable data (e.g., oid4-metadata, persistent keys).

Threat Case 2: Identifiability Risk at Service Providers. Upon activating a WU, the wallet provider generates a set of correlatable pseudo-identifiers (see Figure 2(a)), which do not require revealing the user's identity. However, there is an intrinsic link between the user's attributes and the issuer's signed attestations, especially due to LoA high requirements. When pseudonymous identifiers become persistent or are linked to identifiable data, users risk being identified [33, 97, 99]. Note that WPs are not required to identify but authenticate users (e.g., RAT through PoA).

While APs have access to both wallet pseudo-identifiers and attributable data, RPs that authenticate users using pseudonyms alone may request attributable data for legitimate purposes [99, 111]. This can lead to user re-identification by correlating the requested data with publicly available or auxiliary information [33, 98].

Misactors: RPs, APs, supervisory bodies, and external actors.

Attack Flow: APs collect linked pseudonyms, while RPs or external entities combine these with auxiliary data. This data aggregation enables the re-identification by correlating pseudonymous identifiers with attributable information.

Trigger: RPs can (un)intentionally acquire attributable data when persistent identifiers, such as EAA_{revoc_id}, public keys for verification or transaction logs, are communicated.

Preconditions: Access to pseudo-identifiers that are linked to each other and correlated with attributable data.

Threat Case 3: Linkability, identifiability and excessive data disclosure. Users have the right to use pseudonyms to preserve privacy to ensure that their communications and related data actions remain unidentified and uncorrelated in LoA low use-cases [48, 55]. However, the adoption of pseudonyms remains unspecified; there are exceptional cases in which MSs can limit, restrict, or interfere with fundamental rights, including privacy, under extraordinary circumstances (Recital (69) and Art. 23 of the GDPR [54]).

The EUDIW relies extensively on authenticated actions, attributable data, correlated pseudo-identifiers, and tracking records of user actions. MSs or authoritative entities may compel the disclosure of personally identifiable information [33, 75, 97]. In addition, legislative measures, such as [45] relatives to qualified certificates (i.e., issued by a QTSP), may require the inclusion of government-approved certificates, which may collude with the ARF obligation on registering every RPAC. Qualified certificates, mandated by MSs without due scrutiny, may enable self-signed and forged certificates that serve as sniffing proxy, e.g., large-scale data collection practices, or even governmental surveillance [86, 98].

Misactors: MSs, supervisory bodies.

Attack Flow: Legislative measures force users, APs, or RPs to forcefully collect or disclose sensitive data or process such data without explicit user consent or notice.

Trigger: Legislative measures by MSs in relation to national or public security, prevention or investigation of criminal offenses of economic or financial interest.

Preconditions: EUDIW's core functionalities and communication protocols alongside EU legislation. Pseudo-identifiers that are linked to each other based on attributable data, transaction records, and retention periods.

Threat Case 4: Non-repudiation of data-related actions. In simplistic terms, user authentication has a degree of plausible deniability as long as the authentication is limited to verifying a pseudonym and/or the possession of a valid key pair, that is, PoP, with no attributable data, e.g., linkable PoA. Thus, the user remains unidentified. Even the use of Remote Attestation Procedure (RAT) can help prevent the disclosure of sensitive linkable data, particularly when the same Certification Authority (CA)'s public key is used to validate all proofs of possession. However, the EUDIW enforces specific protocols, OpenID4VCI and OpenID4VP, along with ISO18013-5, that add persistent and correlatable metadata to requests [73]. For instance, the *client_id*, *authorization_token*, client attestations, or the corresponding PoA.

Any additional shared data arising from the exchange of attestations is provided in a signed format. Digitally signed information cannot be repudiated because the signature verification process ensures that there is only one signatory. This is important in the event of disclosing attributes that come signed by both the issuance authority [72], and the user wallet [103]. The corresponding public key for digital signature verification is unique.

Moreover, transaction logs (EU's Regulation 2024/2979 Art. 9 [31], GDPR's Art. 30 [54]) contain attributable data that cannot be repudiated once they are linked to the unique pseudo-identifiers, such as the user's public key or issuer's signature. Intrinsically, non-repudiation risks include linkability and identifiability risks. Additionally, there are tensions between data retention periods,

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

which are usually undetermined, and the right to be forgotten (GDPR's Art. 17) [65], in online and offline scenarios.

Misactors: RPs, MSs, supervisory bodies, or external third parties.
Attack Flow: Upon (un)-intentional revelation of the public key that verifies a signature and it is correlated to an identifiable attribute, the user is uniquely identified (rules out the possibility of plausible deniability). Besides, disclosure of wallet/RPs logs containing attributable and linkable data.
Trigger: User wallet signs electronic transactions, including presentations, with attributable data intended for data sharing.
Preconditions: Proof of Possession (PoP) linked to a Proof of Association (PoA), and EAA which includes signed data.

Threat Case 5: Excessive data disclosure at RP against the risk of service exclusion. Although the ARF obligates RPs to register both the RPAC and attributes to request, and the fact that it integrates selective disclosure of attributes to RP, there is still the risk a RP may end up requesting more (often) than for a certain use case required. For instance, GDPR includes principles of purpose limitation, lawful processing, and information consent principles (GDPR's Art. 5-7, 13, and 28 [54]), which could be interpreted to accommodate a wide range of business interests without clearly defined boundaries [71, 99]. While users have the right to accept or reject any requests for data disclosure, it remains uncertain whether there will be instances of *necessary data disclosure* – like the use of *necessary cookies* – from service providers. RPs should avoid requesting identifiable information (including persistent pseudo-identifier that could be deemed as PII [68]) unless necessary, particularly in authentication-only scenarios (Art. 11 GDPR). Otherwise, users may face exclusion from the service and excessive data disclosure. Even if consented, this may not be justified [99, 111]. The justification for data collection remains unclear and opaque to users; meanwhile, the user's right to object (GDPR's Art. 21) is ignored [71]. Furthermore, the collected data may be used for secondary purposes or shared with third parties, often without users being aware of this fact [39, 97, 99].

Misactors: RP or service providers.
Attack Flow: The RP demands excessive data disclosure in their requests before the provisioning of the service.
Trigger: The user authorizes an RP's presentation request without reviewing or understanding what attributes are requested.
Preconditions: Ambiguous collection and disclosure policy.

Threat Case 6: Insufficient data protection by default. While there are mature designs and technologies for privacy-preserving digital identities [14, 24, 40, 59, 93] that provide user-controllable attributes and enhanced data protection, including guarantees of unlinkability and data minimization, which align with core privacy principles [31, 54], the ARF in compliance with the implementing acts [31, 32] in the use of specific standards, such as OID4VC [72], OID4VP [103], SD-JWT VC [102], OAuth 2.0 Attestation-Based Client Authentication [73], and ISO18013-5 [57] significantly limits the ability to fulfill data protection guarantees.

Even the recently published discussion [52] about potential methods to address linkability risks, such as short-lived or once-only attestations, do not sufficiently address the privacy problem. Some attestations are issued over long periods (e.g., national ID, driving license, or educational degrees) and could potentially be used many times, for instance, for authentication. Regardless of the short-lived credential type, which only defines its validity, it does not prevent the discomposure of attributes. An invalid credential could be rejected but does not prevent the RP from copying and storing relevant data contained within it. Other relevant aspects, such as revocation and general requirements of unlinkability, are mentioned, but no precise method is provided. As such, the ARF creates tensions with GDPR's Art.s 25 and 32 regarding data protection and secure processing. This results in the fact that excessive linkable and attributable data is transmitted over communication and retained over undetermined periods of time.

Misactors: RPs, or external actors.
Attack Flow: (Un)-intentional data access by misactors with access to communication channels or datastores.
Trigger: The EUDIW use of communication protocols that do not accommodate unlinkability along signed data.
Preconditions: EUDIW compliance with EU's regulation on core functionalities and communication protocols [31].

Threat Case 7: Detectability of data-related actions. EUDIW electronic transactions, communication between parties, and data sharing practices occur in traditional Internet networks and in accordance with the communication protocols mandated in the implementation acts [31, 32, 48], such as OpenID4{VCI, VP}, and ISO18013-5. Given the various threat cases described above is explicit that user wallet interactions cannot remain unobserved. Even though communication is secure and authenticated, the added metadata from the protocols and other associated pseudo-identifiers (see Table 1) correlate user actions and sessions. The fact that communication is mutually authenticated suggests that a potentially persistent pseudo-identifier from the user side is in use. Furthermore, these communications may involve the exchange of EAA, which could be stored for extended periods. Note that this argument still applies to offline communication due to the use of mutually authenticated channels through embedded certificates, too.

Misactors: Passive entities to the communication.
Attack Flow: Communication monitoring with correlatable and/or attributable data. (Un)-intended access to data at rest.
Trigger: The active monitoring of user wallet communications or the (un)intended access to data at rest.
Preconditions: EUDIW compliance with EU's regulation on core functionalities and communication protocols [31].

4.4 Privacy Risk Assessment

Our evaluation depends on the contextual framework and recurring assumptions. We devised two primary streams of privacy evaluation that could be taken [1, 74]. On the one hand, quantitative privacy evaluations are based on measurable metrics, such as potential impact and likelihood of the event, to prioritize the corresponding threats [4, 28, 74]. In contrast, qualitative privacy evaluation aims to devise the potential privacy risk to the individual [109], often referred to as privacy harms [98].

We take a qualitative approach, following the method depicted in Figure 3, to evaluate the privacy and clarify the potential harms due to the enumerated threats. We create a mapping of significant privacy harms, according to [98], associated with each threat case as

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

shown in Table 2. We also comprehensively explain each selection in Appendix B. In summary, Table 2 indicates that surveillance and access to auxiliary databases pose risks of data aggregation without user awareness, leading to data disclosure, identification, and insecurity of individuals, with potential for state intrusion. We explain the detailed rationale following structured arguments [105].

Argument 1: Linkability of pseudonyms poses privacy risks. The ARF uses several persistent unique identifiers, including public keys and wallet instance IDs, to establish authenticated and trusted data-sharing practices of attributable data, which allow actors to link sessions [41]. Evidence suggests that RPs collect pseudo-identifiers during communication [71], and these are correlatable to attributable data [68]. Therefore, there exists the risk of both organizational and state surveillance [41, 71, 111].

Argument 2: Identifiability privacy risk. The communication channel between the user's wallet and the RP relies on a set of standards, OpenID4VP and ISO18013-5, and wallet requirements [48] that expose a set of pseudo-identifiers that are not always randomized. In addition, EAA is signed data that undeniably identifies the user. The SD-JWT hides PID by hashing, which creates a persistent fingerprint. Generally, communication entails a data-sharing practice of attributable data, which could link the sessions. Linking attributable data with pseudonyms is a viable practice [68, 97].

Argument 3: Legitimate intervention poses privacy risks ranging from linkability and identifiability to data disclosure. The compliance stance of the ARF mandates authenticated sessions that guarantee high levels of assurance. This fact results in ensuring holder-binding of attestations, which forwards unique cryptographic elements linked to metadata and attributes. In addition to the obligation of retaining logs by both the user wallet solution, intended for reporting purposes, and arbitrarily for the relying parties. Retained logs that contain a myriad of user-attributable data, although collected for business purposes, may end up being shared with third parties, including government agencies [97].

Argument 4: The ARF prevents plausible deniability of data and communication sessions. Electronic Attestation of Attributes arise upon digitally signing a set of claims that intrinsically provide public verification means [67]. Digitally signed data guarantees non-repudiation. Recall that QES have legal and binding effects [53]. Metadata and attributable data may end up correlated during communication by signed instances that cannot be repudiated. A set of attributes and pseudonymous identifiers, when combined, may lead to user re-identification [60]. The risk is exacerbated by re-identification through auxiliary data [35].

Argument 5: Service exclusion risk at the expense of data disclosure. RPs may require significant data disclosure before the service is provided. Similar to cookie banners, RPs may require users to accept these data-sharing requests for business purposes. This data disclosure could be included in the terms of service, which many users tend to ignore or not fully understand [81]. Even when users have the option to opt out of data-sharing practices, there are limited guarantees that SPs will abide by it [71].

Argument 6: The ARF design provides insufficient measures for data protection by default. The specification relies on two protocols, OpenID4{VCI, VP} for online, and ISO18013-5 for offline communications. These protocols do not sufficiently fulfill necessary privacy requirements, primarily unlinkability and data confidentiality [9]. Unlinkability is a requirement for data minimization and unobservability, which needs anonymization of metadata elements [57]. OpenID4VP uses metadata to identify and link requests within sessions. Likewise, the complete communication lifecycle is extensively built upon Public Key Infrastructure for verification, which necessitates public knowledge of verification keys. Meanwhile, the VP in accordance with SD-JWT also relies on immutable hashes for selective disclosure, thus creating a unique fingerprint across sessions [67]. Other identifiers, such as the credential's revocation status, are not addressed.

Argument 7: The ARF design does not allow unobservable electronic transactions. Arguably, all the aforementioned claims suggest that unobservable communication is not possible. The ARF does not adequately address unlinkability, identifiability, or plausible deniability of data-related actions and, therefore, does not provide a system that remains undistinguished from other interactions. A system is anonymous if the links that unambiguously associate and identify subjects are removed [60, 92]. Furthermore, the system is undetectable or unobservable if its actions cannot be adequately distinguished from others [87].

Privacy Harm	Threat Case						
	1	2	3	4	5	6	7
Surveillance	×	×	×	×	×	×	×
Interrogation							
Aggregation	×	×	×	×	×	×	×
Identification	×	×	×	×	×	×	×
Insecurity	×	×	×	×	×	×	×
Secondary Use	×	×	×	×	×	×	
Exclusion	×	×	×	×	×	×	×
Breach of Confidentiality	×	×	×	×	×	×	×
Disclosure	×	×	×	×	×	×	×
Exposure							
Increased Accessibility	×	×	×	×	×	×	×
Blackmail							
Appropriation				×		×	
Distortion						×	
Intrusion	×	×	×	×	×	×	×
Decisional Interference	×	×	×	×	×	×	×

Table 2: Privacy harms mapping to threat cases [99].

5 Privacy-Enhancing Technologies Selection

As previously demonstrated, the ARF has several privacy shortcomings, mainly as it does not prevent the disclosure of linkable cryptographic identifiers and further unnecessary personally identifiable information. These challenges arise from its strong reliance on existing standardized protocols such as OpenID4{VCI, VP} and ISO18013-5 [31], as well as data schemas like SD-JWT VC, which prioritize interoperability and verifiability but lack built-in mechanisms for strong data minimization and unlinkability. Addressing these gaps requires integrating state-of-the-art PETs that offer more capable disclosure controls beyond simple selective disclosure and

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

static attributes for predicate proofs, while addressing real-world requirements such as compatibility with WSCD components.

The state-of-the-art method for data minimization and enhanced user data control is the ZKP suite [43]. We find two lines of work generally based on non-standardized cryptographic components, purpose-specific and general-purpose ZKP [5, 93], as well as one stream employing direct anonymous attestation, through tamper-resistant hardware [69]. ZKPs are arguably the most widespread approach to minimize the disclosure of personally identifiable data and facilitating both AP and RP unlinkability [5, 9, 15, 23, 69, 93].

The zero-knowledge property offers a perfect means of data minimization: While generally being defined as "those proofs that convey no additional knowledge other than the correctness of the proposition in question" [62], their application in the context of presenting digital certificates such as WUAs and EAAs allows the holder (prover) to demonstrate ownership of a valid certificate with certain properties while hiding any subset of (cryptographic) information in the certificate. In particular, the ZKP usually includes a proof of knowledge of a valid signature associated with the issuer's public key, and a proof of knowledge of the private key for holder binding [61].

While purpose-specific ZKP constructions, such as BBS+ [12], are usually limited to specific signature types and selective disclosure [18, 23], the general-purpose ones, such as zk-SNARKs [16], can additionally cover any predicates (i.e., results of a computation on any values in the certificate, including identity attributes) without revealing the underlying attributes themselves [37, 93]. As all integrity, authenticity, and validity checks are in particular predicate proofs (e.g., the predicate that computes the result of the verification of the holder's digital signature on the random challenge received from the RP ensures proper holder binding and replay prevention), it is apparent that general-purpose ZKPs are also well suitable for cryptographic agility and being compatible with any form of credential formats or digital signature primitives. This makes them compatible with existing embedded secure elements on mobile phones that support ECDSA signatures but not the operations necessary for special-purpose ZKPs such as BBS+. While the main limitation of general-purpose ZKPs is prover resources and in particular proving time, Frigo and shelat [58] recently implemented zk-SNARKs with practical proving time (few seconds on a mobile phone) for the ISO18013-5 format [57] which are compatible with cryptographic operations supported by the WSCD (ECDSA signatures with the NIST-P curve / secp256r1). Moreover, this approach avoids the need to clutter and frequently update an attestation with multiple attributes, such as *age_over_18, age_over_21, age_over_67* as it is currently foreseen in the eIDASs implementing acts [48, 102] for data-minimizing age proofs as foreseen in the OpenID4VP and ISO18013-5 standards [57, 103].

After all, the ARF already supports two attestation formats that do support ZKP, namely: W3C DM v1.1 [100] and W3C DM v2.0 [101]. While W3C DM v1.1 utilizes CL signatures [23], W3C DM v2.0 features an expanded cryptographic suite that includes BBS signatures [12]. Both formats provide strong privacy measures, such as the unlinkability of VPs when ZKP are used. However, the supported hardware adoption is limited [26, 69]. Therefore, the ARF employs SD-JWT data format with standardized cryptographic architecture.

Furthermore, digital identities can benefit from the Trusted Computing Group's tamper-resistant hardware initiatives [20]. The work presented in [26] introduces attributes into this specification, effectively incorporating specific ZKP methods such as CL-based signatures into the hardware. This construction enables selective disclosure and ensures unlinkability; however, it does not accommodate complex predicates. Larsen et al. [69] extends this work into a potential alternative to verifiable attestations. Although these approaches facilitate privacy-enhancing methods for signature verification with high assurance levels – such as a remote attestation procedure – they lack a developed data specification for digital attestations.

6 Discussion

In this paper, we showcase that the current ARF for the EUDIW falls short of fulfilling its privacy by default promises. While the EUDIW undoubtedly represents a step in the right direction compared to existing digital identity infrastructures, a gap remains in covering the promised privacy requirements, particularly regarding unlinkability. The ARF describes a digital wallet model that ensures a high degree of trustworthiness in the ecosystem. These high trust assurances are given by certified bodies that produce certified and signed data on multiple layers (see Section 3, and Figure 2). However, the verification processes of these certifications entail the disclosure of persistent cryptographic identifiers that not only pose privacy risks through likability but also lack users' awareness and, therefore, consent regarding their disclosure. In particular, the ARF does not adequately address the unlinkability of WUAs and EAAs. It also does not address other equally important privacy requirements, such as the avoidance of potentially excessive disclosure of identity attributes, risks of identification due to lack of privacy policies, plausible deniability due to signed data and correlatable logs, and unobservability of wallet actions.

We underscore that this misalignment between promised and realized privacy design requirements arises from the regulatory framework the EUDIW is based on. On the one hand, EU legislation, including the implementing acts corresponding to eIDAS 2.0 [50, 51, 55], aim to use trusted and secure technologies for data sharing to ensure data protection. On the other hand, in order to facilitate a high degree of interoperability, the ARF restricts both the set of technologies to achieve this goal and the corresponding protocols (OpenID4{VCI, VP} and ISO18013-5) for issuing and presenting attestations in online and offline settings, respectively.

While the ARF mentions the potential use of ZKPs to augment privacy guarantees in verifiable presentations, e.g., by issuing EAAs in more ZKP-friendly formats such as the W3C VC DM v1.1 [100] and v2.0 [101], most attention has been paid to wallet solutions supporting the SD-JWT format. The W3C VC Data Model follows a stringent trajectory towards ZKPs. For instance, while the W3C VC DM v1.1 only mentions CL signatures [23], the W3C VC DM v2.0 extensively supports the more efficient BBS signatures [18]. Both are purpose-specific ZKPs that allow the user to prove the possession of a signed attestation and to selectively disclose attributes. On the other hand, both CL and BBS signatures are not supported by the embedded secure elements available on mobile phones [5]. Thus, we suggest more attention to (general-purpose)

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

ZKPs to address such privacy concerns, design system requirements not only to adapt to real-world restrictions but also accommodating a wide range of predicates [58, 93], and even potential regulatory compliance [90]. Specifically, transactions that cater to temporary use cases could greatly improve privacy. Moreover, SPs could utilize short-lived ephemeral communication, allowing the user to provide only the necessary data for the requested service instead of retaining and storing information long-term.

Privacy is inherently interpretative, and the level of protection a solution can achieve is not only influenced by technical design choices. While data minimizing transactions that do not disclose any information beyond what the RP explicitly requests are technically possible [11, 19, 23, 24, 93], this request needs to align with EU transparency and accountability requirements [53, 55]. Conversely, compliant solutions like the EUDIW [44] may decrease user privacy to safeguard accountability or for enhanced security measures, such as recording device- and operating system related information in the WUA. As such, the regulatory frameworks necessarily shaped the ARF and entail trade-offs for privacy. Our analysis accounts for these constraints to provide a balanced evaluation.

We did not cover all key use cases of the EUDIW introduced in the ARF to maintain a reasonable degree of detail on the arguably most critical use cases. For instance, this research does not evaluate QES, which works rather distinctly. However, with QES involving a high degree of accountability and, thus, PID data disclosure, fewer privacy issues are to be expected. We also concentrate on generic EAA but do not delve into more specific applications like single-use credentials for the electronic prescriptions use case. Additionally, we focused on the application and data exchange layers [34] and ignored network-based security and privacy aspects [6], relying on the underlying security premises of, e.g., BLE or Transport Layer Security (TLS).

7 Conclusion

The Architecture and Reference Framework (ARF) provides the technical backbone of the EU Digital Identity Wallet (EUDIW) within the electronic Identification, Authentication and Trust Services (eIDAS) 2.0 framework [48, 55], aiming to provide a secure and interoperable digital identity solution across the EU. Even though the eIDAS 2.0 regulation calls for privacy-by-design, previous research, such as [9], has identified significant privacy challenges, particularly regarding the lack of unlinkability. This work extends previous analyses by systematically assessing and evaluating the privacy properties of the EUDIW resulting from the ARF through a structured privacy threat modeling approach using the LINDDUN framework [39]. To do so, we model the information flow of presenting attestations with the protocols and attestation formats specified in the ARF, considering associated attestations such as WUA and corresponding cryptographic metadata, and derive privacy threats across different use cases and stakeholders.

Our findings indicate that the ARF (v1.5) does not fully satisfy privacy-by-design principles [25], with key challenges arising from linkability, and identifiability [9], non-repudiation [13], detectability, and data disclosure [90]. These issues primarily stem from the ARF's requirements and the reliance on protocols such as OpenID4{VCI, VP} and ISO18013-5, which introduce persistent identifiers, transaction logs, and metadata that can lead to tracking and correlation across sessions. Additionally, regulatory requirements that introduce additional artifacts such as the WUA shall strengthen trust and ensure LoA high, create additional risks.

While the EUDIW represents a step towards a unified and user-centric digital identity framework, its current design does not deliver on its privacy commitments. Achieving strong privacy-by-design principles requires adopting technical measures that ensure formal privacy guarantees [25]. Future research should explore how privacy-enhancing technologies, such as anonymous credentials [23], particularly from (general-purpose) ZKPs [5, 37, 58, 69, 93], can be effectively integrated into the EUDIW while bridging existing gaps and tensions between security, usability, and privacy.

Acknowledgments

This research was supported in part by Luxembourg's Ministry for Digitalisation, PayPal, and the Luxembourg National Research Fund (FNR) (P17/IS/13342933/ PayPalFNR/Chair in DFS/Gilbert Fridgen and PABLO, grant reference 16326754)). For the purpose of open access and in fulfillment of the obligations arising from the grant agreements, the authors have applied a Creative Commons Attribution 4.0 International (CC BY 4.0) license to any Author Accepted Manuscript version arising from this submission. The authors acknowledge the use of Grammarly's generative AI features to enhance the clarity, grammar, and coherence of their writing by refining sentence structure.

CRediT author statement

Iván Abellán Álvarez: Conceptualization; Methodology; Investigation; Formal analysis; Visualization; Project administration; Writing - original draft; and Writing - review & editing.
Pol Hölzmer: Conceptualization; Methodology; Investigation; Validation; Visualization; Project administration; Writing - review & editing.
Johannes Sedlmeir: Conceptualization; Methodology; Funding acquisition; Supervision; Writing - review & editing.

References

[1] Sushant Agarwal. 2016. Developing a Structured Metric to Measure Privacy Risk in Privacy Impact Assessments. In *Privacy and Identity Management. Time for a Revolution?*, David Aspinall, Jan Camenisch, Marit Hansen, Simone Fischer-Hübner, and Charles Raab (Eds.). Vol. 476. Springer International Publishing, Cham, 141–155. https://doi.org/10.1007/978-3-319-41763-9_10 Series Title: IFIP Advances in Information and Communication Technology.

[2] Christopher Allen. 2016. The Path to Self-Sovereign Identity. https://github.com/WebOfTrustInfo/self-sovereign-identity github.com/WebOfTrustInfo/self-sovereign-identity.

[3] Zahra Ebadi Ansaroudi, Roberto Carbone, Giada Sciarretta, and Silvio Ranise. 2023. Control is Nothing Without Trust a First Look into Digital Identity Wallet Trends. In *Data and Applications Security and Privacy XXXVII*, Vijayalakshmi Atluri and Anna Lisa Ferrara (Eds.). Vol. 13942. Springer Nature Switzerland, Cham, 113–132. https://doi.org/10.1007/978-3-031-37586-6_7 Series Title: Lecture Notes in Computer Science.

[4] Ashwini Bijwe and Nancy R. Mead. 2018. Adapting the Square process for privacy requirements engineering. (2018), 677002 Bytes. https://doi.org/10.1184/R1/6571826.V1 Artwork Size: 677002 Bytes Publisher: Figshare.

[5] Matthias Babel and Johannes Sedlmeir. 2023. Bringing data minimization to digital wallets at scale with general-purpose zero-knowledge proofs. https://doi.org/10.48550/arXiv.2301.00823 arXiv:2301.00823 [cs].

[6] Christian Badertscher, Fabio Banfi, and Jesus Diaz. 2024. What Did Come Out of It? Analysis and Improvements of DIDComm Messaging. In *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security.*

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

ACM, Salt Lake City UT USA, 4732–4746. https://doi.org/10.1145/3658644.3690300

[7] Emanuele Baldacci and Joao Rodrigues Frade. 2021. Advancing Digital Transformation in the Public Sector with Blockchain: A View from the European Union. In *Disintermediation Economics*, Eva Kaili and Dimitrios Psarrakis (Eds.). Springer International Publishing, Cham, 281–295. https://doi.org/10.1007/978-3-030-65781-9_13

[8] Foteini Baldimtsi, Konstantinos Kryptos Chalkias, Yan Ji, Jonas Lindstrøm, Deepak Maram, Ben Riva, Arnab Roy, Mahdi Sedaghat, and Joy Wang. 2024. zkLogin: Privacy-Preserving Blockchain Authentication with Existing Credentials. In *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security*. ACM, Salt Lake City UT USA, 3182–3196. https://doi.org/10.1145/3658644.3690356

[9] Carsten Baum, Olivier Blazy, Jan Camenisch, Jaap-Henk Hoepman, Eysa Lee, Anja Lehmann, Anna Lysyanskaya, René Mayrhofer, Hart Montgomery, and Ngoc Khanh Nguyen. 2024. *Cryptographers' Feedback on the EU Digital Identity's ARF*. Technical Report. https://files.dyne.org/eudi/cryptographers-feedback-june2024.pdf

[10] Marta Beltrán and Miguel Calvo. 2023. A privacy threat model for identity verification based on facial recognition. *Computers & Security* 132 (Sept. 2023), 103324. https://doi.org/10.1016/j.cose.2023.103324

[11] Eli Ben Sasson, Alessandro Chiesa, Christina Garman, Matthew Green, Ian Miers, Eran Tromer, and Madars Virza. 2014. Zerocash: Decentralized Anonymous Payments from Bitcoin. In *2014 IEEE Symposium on Security and Privacy*. IEEE, San Jose, CA, 459–474. https://doi.org/10.1109/SP.2014.36

[12] Greg Bernstein and Manu Sporny. 2025. Data Integrity BBS Cryptosuites v1.0. https://www.w3.org/TR/vc-di-bbs/

[13] Magdalena Bertram, Maximilian Richter, and Marian Margraf. 2024. Achieving Third-party Deniability in Signature-based Credential Systems. In *2024 IEEE 48th Annual Computers, Software, and Applications Conference (COMPSAC)*. IEEE, Osaka, Japan, 2327–2333. https://doi.org/10.1109/COMPSAC61105.2024.00374

[14] Patrik Bichsel, Jan Camenisch, Maria Dubovitskaya, Robert R. Enderlein, Stephan Krenn, Ioannis Krontiris, Anja Lehmann, Gregory Neven, Christian Paquin, Franz-Stefan Preiss, Kai Rannenberg, and Ahmad Sabouri. 2015. An Architecture for Privacy-ABCs. In *Attribute-based Credentials for Trust*, Kai Rannenberg, Jan Camenisch, and Ahmad Sabouri (Eds.). Springer International Publishing, Cham, 11–78. https://doi.org/10.1007/978-3-319-14439-9_2

[15] Patrik Bichsel, Jan Camenisch, Maria Dubovitskaya, Robert R. Enderlein, Stephan Krenn, Anja Lehmann, Gregory Neven, and Franz-Stefan Preiss. 2015. Cryptographic Protocols Underlying Privacy-ABCs. In *Attribute-based Credentials for Trust*, Kai Rannenberg, Jan Camenisch, and Ahmad Sabouri (Eds.). Springer International Publishing, Cham, 79–108. https://doi.org/10.1007/978-3-319-14439-9_3

[16] Nir Bitansky, Ran Canetti, Alessandro Chiesa, Shafi Goldwasser, Huijia Lin, Aviad Rubinstein, and Eran Tromer. 2017. The Hunting of the SNARK. *Journal of Cryptology* 30, 4 (Oct. 2017), 989–1066. https://doi.org/10.1007/s00145-016-9241-9

[17] Ricardo Bochnia, Daniel Richter, and Jürgen Anke. 2024. Self-sovereign identity for organizations: requirements for enterprise software. *IEEE Access* 12 (2024), 7637–7660.

[18] Dan Boneh, Xavier Boyen, and Hovav Shacham. 2004. Short Group Signatures. In *Advances in Cryptology – CRYPTO 2004 (Lecture Notes in Computer Science)*, Matt Franklin (Ed.). Springer, Berlin, Heidelberg, 41–55. https://doi.org/10.1007/978-3-540-28628-8_3

[19] Sean Bowe, Alessandro Chiesa, Matthew Green, Ian Miers, Pratyush Mishra, and Howard Wu. 2020. ZEXE: Enabling Decentralized Private Computation. In *2020 IEEE Symposium on Security and Privacy (SP)*. IEEE, San Francisco, CA, USA, 947–964. https://doi.org/10.1109/SP40000.2020.00050

[20] Ernie Brickell, Jan Camenisch, and Liqun Chen. 2004. Direct anonymous attestation. In *Proceedings of the 11th ACM conference on Computer and communications security*. ACM, Washington DC USA, 132–145. https://doi.org/10.1145/1030083.1030103

[21] M. Ryan Calo. 2011. The Boundaries of Privacy Harm. *Indiana Law Journal* 86, 3 (2011). https://www.repository.law.indiana.edu/ilj/vol86/iss3/8

[22] Jan Camenisch, Markulf Kohlweiss, and Claudio Soriente. 2009. An accumulator based on bilinear maps and efficient revocation for anonymous credentials. In *International Workshop on Public Key Cryptography*. Springer, 481–500. https://doi.org/10.1007/978-3-642-00468-1_27

[23] Jan Camenisch and Anna Lysyanskaya. 2004. Signature Schemes and Anonymous Credentials from Bilinear Maps. In *Advances in Cryptology – CRYPTO 2004 (Lecture Notes in Computer Science)*, Matt Franklin (Ed.). Springer, Berlin, Heidelberg, 56–72. https://doi.org/10.1007/978-3-540-28628-8_4

[24] Jan Camenisch and Els Van Herreweghen. 2002. Design and implementation of the *idemix* anonymous credential system. In *Proceedings of the 9th ACM conference on Computer and communications security*. ACM, Washington, DC USA, 21–30. https://doi.org/10.1145/586110.586114

[25] Ann Cavoukian and others. 2021. Privacy by design: The seven foundational principles. *IAPP Resource Center* (2021).

[26] Liqun Chen and Rainer Urian. 2015. DAA-A: Direct Anonymous Attestation with Attributes. In *Trust and Trustworthy Computing*, Mauro Conti, Matthias Schunter, and Ioannis Askoxylakis (Eds.). Vol. 9229. Springer International Publishing, Cham, 228–245. https://doi.org/10.1007/978-3-319-22846-4_14 Series Title: Lecture Notes in Computer Science.

[27] Cloud Signature Consortium. 2023. Architectures and protocols for remote signature applications. https://cloudsignatureconsortium.org/wp-content/uploads/2023/04/csc-api-v2.0.0.2.pdf

[28] CNiL. 2015. Privacy impact assessment (PIA): Methodology (how to carry out a PIA). https://www.cnil.fr/sites/cnil/files/typo/document/CNIL-PIA-1-Methodology.pdf

[29] Julie E. Cohen. 2000. Examined Lives: Informational Privacy and the Subject as Object. *Stanford Law Review* 52, 5 (May 2000), 1373. https://doi.org/10.2307/1229517

[30] Comission. 2014. Commission Implementing Regulation (EU) 2024/2977 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards person identification data and electronic attestations of attributes issued to European Digital Identity Wallets. *Official Journal of the European Union* (Dec. 2014). http://data.europa.eu/eli/reg_impl/2024/2977/oj

[31] Comission. 2014. Commission Implementing Regulation (EU) 2024/2979 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the integrity and core functionalities of European Digital Identity Wallets. *Official Journal of the European Union* (Dec. 2014). http://data.europa.eu/eli/reg_impl/2024/2979/oj

[32] Comission. 2014. Commission Implementing Regulation (EU) 2024/2982 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards protocols and interfaces to be supported by the European Digital Identity Framework. *Official Journal of the European Union* (Dec. 2014). http://data.europa.eu/eli/reg_impl/2024/2982/oj

[33] Kate Crawford and Jason Schultz. 2014. Big Data and Due Process: Toward a Framework to Redress Predictive Privacy Harms. *Boston College Law Review* (Jan. 2014).

[34] Matthew Davie, Dan Gisolfi, Daniel Hardman, John Jordan, Darrell O'Donnell, and Drummond Reed. 2019. The Trust over IP stack. *IEEE Communications Standards Magazine* 3, 4 (2019), 46–51. Publisher: IEEE.

[35] Yves-Alexandre De Montjoye, Laura Radaelli, Vivek Kumar Singh, and Alex "Sandy" Pentland. 2015. Unique in the shopping mall: On the reidentifiability of credit card metadata. *Science* 347, 6221 (Jan. 2015), 536–539. https://doi.org/10.1126/science.1256297

[36] Konrad Degen and Timm Teubner. 2024. Wallet wars or digital public infrastructure? Orchestrating a digital identity data ecosystem from a government perspective. *Electronic Markets* 34, 1 (Dec. 2024), 50. https://doi.org/10.1007/s12525-024-00731-1

[37] Antoine Delignat-Lavaud, Cédric Fournet, Markulf Kohlweiss, and Bryan Parno. 2016. Cinderella: Turning shabby X. 509 certificates into elegant anonymous credentials with the magic of verifiable computation. In *2016 IEEE Symposium on Security and Privacy (SP)*. IEEE, 235–254.

[38] Tom DeMarco. 2002. Structured Analysis and System Specification. In *Software Pioneers*, Manfred Broy and Ernst Denert (Eds.). Springer Berlin Heidelberg, Berlin, Heidelberg, 529–560. https://doi.org/10.1007/978-3-642-59412-0_33

[39] Mina Deng, Kim Wuyts, Riccardo Scandariato, Bart Preneel, and Wouter Joosen. 2011. A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements. *Requirements Engineering* 16, 1 (March 2011), 3–32. https://doi.org/10.1007/s00766-010-0115-7

[40] Jack Doerner, Yashvanth Kondi, Eysa Lee, Abhi Shelat, and LaKyah Tyner. 2023. Threshold BBS+ Signatures for Distributed Anonymous Credential Issuance. In *2023 IEEE Symposium on Security and Privacy (SP)*. IEEE, San Francisco, CA, USA, 773–789. https://doi.org/10.1109/SP46215.2023.10179470

[41] Steven Englehardt, Dillon Reisman, Christian Eubank, Peter Zimmerman, Jonathan Mayer, Arvind Narayanan, and Edward W. Felten. 2015. Cookies That Give You Away: The Surveillance Implications of Web Tracking. In *Proceedings of the 24th International Conference on World Wide Web*. International World Wide Web Conferences Steering Committee, Florence Italy, 289–299. https://doi.org/10.1145/2736277.2741679

[42] Jens Ernstberger, Jan Lauinger, Fatima Elsheimy, Liyi Zhou, Sebastian Steinhorst, Ran Canetti, Andrew Miller, Arthur Gervais, and Dawn Song. 2023. SoK: Data Sovereignty. In *2023 IEEE 8th European Symposium on Security and Privacy (EuroS&P)*. 122–143. https://doi.org/10.1109/EuroSP57164.2023.00017

[43] ETSI. 2024. *Electronic Signatures and Trust Infrastructures (ESI); Analysis of selective disclosure and zero-knowledge proofs applied to Electronic Attestation of Attributes*. RTR/ESI-0019476v121 TR 119 476. https://www.etsi.org/deliver/etsi_tr/119400_119499/119476/01.02.01_60/tr_119476v010201p.pdf

[44] European Commission. 2014. Commission Implementing Regulation (EU) 2024/2981 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and the Council as regards the certification of European Digital Identity Wallets. *Official Journal of the*

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

European Union (Dec. 2014). http://data.europa.eu/eli/reg_impl/2024/2981/oj

[45] European Commission. 2014. COMMISSION STAFF WORKING DOCUMENT Accompanying the document REPORT FROM THE COMMISSION TO THE EUROPEAN PARLIAMENT AND THE COUNCIL on the evaluation of Regulation (EU) No 910/2014 on electronic identification and trust services for electronic transactions in the internal market (eIDAS). (Dec. 2014). https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:52021SC0130

[46] European Commission. 2019. European Digital Identity. https://commission.europa.eu/strategy-and-policy/priorities-2019-2024/europe-fit-digital-age/european-digital-identity_en

[47] European Commission. 2021. eID: Offers digital services capable of electronically identifying users from all across Europe. https://ec.europa.eu/digital-building-blocks/sites/digital-building-blocks/sites/display/DIGITAL/eID

[48] European Commission. 2021. European Digital Identity Wallet Architecture and Reference Framework (v1.5). https://github.com/eu-digital-identity-wallet/eudi-doc-architecture-and-reference-framework/tree/v1.5.0

[49] European Commission. 2021. Proposal for a REGULATION OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL amending Regulation (EU) No 910/2014 as regards establishing a framework for a European Digital Identity. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:52021PC0281

[50] European Commission. 2024. Commission Implementing Regulation (EU) 2024/2977 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards person identification data and electronic attestations of attributes issued to European Digital Identity Wallets. https://eur-lex.europa.eu/eli/reg_impl/2024/2977/oj/eng Doc ID: 32024R2977 Doc Sector: 3 Doc Title: Commission Implementing Regulation (EU) 2024/2977 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards person identification data and electronic attestations of attributes issued to European Digital Identity Wallets Doc Type: R Usr_lan: en.

[51] European Commission. 2024. Commission Implementing Regulation (EU) 2024/2979 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the integrity and core functionalities of European Digital Identity Wallets. https://eur-lex.europa.eu/eli/reg_impl/2024/2979/oj/eng Doc ID: 32024R2979 Doc Sector: 3 Doc Title: Commission Implementing Regulation (EU) 2024/2979 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the integrity and core functionalities of European Digital Identity Wallets Doc Type: R Usr_lan: en.

[52] European Commission. 2025. European Digital Identity Wallet Architecture and Reference Framework - Privacy risks and mitigation. https://github.com/eu-digital-identity-wallet/eudi-doc-architecture-and-reference-framework/blob/main/docs/discussion-topics/a-privacy-risks-and-mitigations.md

[53] European Parliament and Council of the European Union. 2014. Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC. *Official Journal of the European Union* (Aug. 2014), 73–114. http://data.europa.eu/eli/reg/2014/910/oj

[54] European Parliament and Council of the European Union. 2016. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation). *Official Journal of the European Union* (May 2016), 1–88. http://data.europa.eu/eli/reg/2016/679/oj

[55] European Parliament and Council of the European Union. 2024. Regulation (EU) 2024/1183 of the European Parliament and of the Council of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework. *Official Journal of the European Union* (April 2024). http://data.europa.eu/eli/reg/2024/1183/oj

[56] International Organization for Standardization. 2021. Information security, cybersecurity and privacy protection — Requirements for attribute-based unlinkable entity authentication. https://www.iso.org/standard/72018.html

[57] International Organization for Standardization. 2021. Personal identification — ISO-compliant driving licence — Part 5: Mobile driving licence (mDL) application. https://www.iso.org/standard/69084.html

[58] Matteo Frigo and abhi shelat. 2024. Anonymous credentials from ECDSA. https://eprint.iacr.org/2024/2010 Published: Cryptology ePrint Archive, Paper 2024/2010.

[59] Jesús García-Rodriguez, Stephan Krenn, Jorge Bernal Bernabe, and Antonio Skarmeta. 2024. Beyond selective disclosure: Extending distributed p-ABC implementations by commit-and-prove techniques. *Computer Networks* 248 (June 2024), 110498. https://doi.org/10.1016/j.comnet.2024.110498

[60] Simson L. Garfinkel. 2015. *De-identification of personal information.* Technical Report NIST IR 8053. National Institute of Standards and Technology. NIST IR 8053 pages. https://doi.org/10.6028/NIST.IR.8053

[61] Jana Glöckler, Johannes Sedlmeir, Muriel Frank, and Gilbert Fridgen. 2023. A Systematic Review of Identity and Access Management Requirements in Enterprises and Potential Contributions of Self-Sovereign Identity. *Business & Information Systems Engineering* (Sept. 2023). https://doi.org/10.1007/s12599-023-00830-x

[62] Shafi Goldwasser, Silvio Micali, and Charles Rackoff. 1989. The knowledge complexity of interactive proof systems. *SIAM J. Comput.* 18 (1989), 186–208. Issue 1. https://doi.org/10.1137/0218012

[63] Dick Hardt. 2012. The OAuth 2.0 Authorization Framework. https://doi.org/10.17487/RFC6749 Issue: 6749 Num Pages: 76 Series: Request for Comments Published: RFC 6749.

[64] Gerrit Hornung and Christoph Schnabel. 2009. Data protection in Germany I: The population census decision and the right to informational self-determination. *Computer Law & Security Review* 25, 1 (2009), 84–88.

[65] Stefan Albert Horstmann, Samuel Domiks, Marco Gutfleisch, Mindy Tran, Yasemin Acar, Veelasha Moonsamy, and Alena Naiakshina. 2024. "Those things are written by lawyers, and programmers are reading that." Mapping the Communication Gap Between Software Developers and Privacy Experts. *Proceedings on Privacy Enhancing Technologies* 2024, 1 (Jan. 2024), 151–170. https://doi.org/10.56553/popets-2024-0010

[66] Kim Peiter Jørgensen and Roman Beck. 2022. Universal Wallets. *Business & Information Systems Engineering* 64, 1 (Feb. 2022), 115–125. https://doi.org/10.1007/s12599-021-00736-6

[67] Jonathan Katz. 2010. *Digital Signatures.* Springer US, Boston, MA. https://doi.org/10.1007/978-0-387-27712-7

[68] Balachander Krishnamurthy and Craig E. Wills. 2010. On the leakage of personally identifiable information via online social networks. *ACM SIGCOMM Computer Communication Review* 40, 1 (Jan. 2010), 112–117. https://doi.org/10.1145/1672308.1672328

[69] Benjamin Larsen, Nada El Kassem, Thanassis Giannetsos, Ioannis Krontiris, Stefanos Vasileiadis, and Liqun Chen. 2023. Achieving Higher Level of Assurance in Privacy Preserving Identity Wallets. In *2023 IEEE 22nd International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*. 1049–1059. https://doi.org/10.1109/TrustCom60117.2023.00146 ISSN: 2324-9013.

[70] Cristian Lepore, Romain Laborde, and Jessica Eynard. 2024. Aligning eIDAS and Trust Over IP: A Mapping Approach. In *Proceedings of the 19th International Conference on Availability, Reliability and Security (ARES '24)*. Association for Computing Machinery, New York, NY, USA, 1–9. https://doi.org/10.1145/3664476.3670919

[71] Zengrui Liu, Umar Iqbal, and Nitesh Saxena. 2024. Opted Out, Yet Tracked: Are Regulations Enough to Protect Your Privacy? *Proceedings on Privacy Enhancing Technologies* 2024, 1 (Jan. 2024), 280–299. https://doi.org/10.56553/popets-2024-0016

[72] T. Lodderstedt, K. Yasuda, and T. Looker. 2024. OpenID for Verifiable Credential Issuance - draft 15. https://openid.net/specs/openid-4-verifiable-credential-issuance-1_0.html

[73] Tobias Looker, Paul Bastian, and Christian Bormann. 2024. *OAuth 2.0 Attestation-Based Client Authentication.* Internet-Draft draft-ietf-oauth-attestation-based-client-auth-04. Internet Engineering Task Force. https://datatracker.ietf.org/doc/draft-ietf-oauth-attestation-based-client-auth/04/ Backup Publisher: Internet Engineering Task Force Num Pages: 20.

[74] Jesus Luna, Neeraj Suri, and Ioannis Krontiris. 2012. Privacy-by-design based on quantitative threat modeling. In *2012 7th International Conference on Risks and Security of Internet and Systems (CRiSIS)*. IEEE, Cork, Ireland, 1–8. https://doi.org/10.1109/CRISIS.2012.6378941

[75] David Lyon. 2014. Surveillance, Snowden, and Big Data: Capacities, consequences, critique. *Big Data & Society* 1, 2 (July 2014), 2053951714541861. https://doi.org/10.1177/2053951714541861

[76] Giuseppe De Marco, Francesco Antonio Marino, and Andrea De Maria. 2024. Bridging eIDAS 2.0 Legal Requirements and Technical Solutions. In *Proceedings of the 2nd International Workshop on Trends in Digital Identity (TDI 2024), Rome, Italy, April 9, 2024 (CEUR Workshop Proceedings, Vol. 3863)*, Giada Sciarretta and Marco Pernpruner (Eds.). CEUR-WS.org, 18–30. https://ceur-ws.org/Vol-3863/paper2.pdf

[77] Luca Mattei, Francesca Morpurgo, Carmela Occhipinti, Lorenzo Maria Ratto Vaquer, and Tetiana Vasylieva. 2024. Self-Sovereign Identity Model: Ethics and Legal Principles. *Digital Society* 3, 2 (Aug. 2024), 25. https://doi.org/10.1007/s44206-024-00113-2

[78] D. Moher, A. Liberati, J. Tetzlaff, and D. G Altman. 2009. Preferred reporting items for systematic reviews and meta-analyses: the PRISMA statement. *BMJ* 339, 1 (2009). https://doi.org/10.1136/bmj.b2535

[79] Nesrine Kaaniche, Maryline Laurent, and Sana Belguith. 2020. Privacy enhancing technologies for solving the privacy-personalization paradox: Taxonomy and survey. *Journal of Network and Computer Applications* 171 (Dec. 2020), 102807. https://doi.org/10.1016/j.jnca.2020.102807 Publisher: Academic Press.

[80] Carly Nyst and Tomaso Falchetta. 2017. The Right to Privacy in the Digital Age. *Journal of Human Rights Practice* 9, 1 (Feb. 2017), 104–118. https://doi.org/10.1093/jhuman/huw026

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

[81] Jonathan A. Obar and Anne Oeldorf-Hirsch. 2020. The biggest lie on the Internet: ignoring the privacy policies and terms of service policies of social networking services. *Information, Communication & Society* 23, 1 (Jan. 2020), 128–147. https://doi.org/10.1080/1369118X.2018.1486870
[82] OECD. 2023. *Report on the implementation of the OECD Privacy Guidelines*. OECD Digital Economy Papers 361. https://doi.org/10.1787/cf87ae8f-en Series: OECD Digital Economy Papers Volume: 361.
[83] Marie Caroline Oetzel and Sarah Spiekermann. 2014. A systematic methodology for privacy impact assessments: a design science approach. *European Journal of Information Systems* 23, 2 (March 2014), 126–150. https://doi.org/10.1057/ejis.2013.18
[84] OpenID Connect. 2023. Self-Issued OpenID Provider v2 - draft 13. https://openid.net/specs/openid-connect-self-issued-v2-1_0.html
[85] Frank Pallas, Katharina Koerner, Isabel Barberá, Jaap-Henk Hoepman, Meiko Jensen, Nandita Rao Narla, Nikita Samarin, Max-R Ulbricht, Isabel Wagner, Kim Wuyts, et al. 2024. Privacy engineering from principles to practice: A roadmap. *IEEE Security & Privacy* 22, 2 (2024), 86–92.
[86] Jonathon W. Penney. 2016. Chilling Effects: Online Surveillance and Wikipedia Use. (2016). https://doi.org/10.15779/Z38SS13 Publisher: [object Object].
[87] Andreas Pfitzmann, TU Dresden, and Marit Hansen. 2010. A terminology for talking about privacy by data minimization: Anonymity, Unlinkability, Undetectability, Unobservability, Pseudonymity, and Identity Management. (Aug. 2010).
[88] Ania M. Piotrowska. 2021. Studying the Anonymity Trilemma with a Discrete-event Mix Network Simulator. In *Proceedings of the 20th Workshop on Workshop on Privacy in the Electronic Society*. ACM, Virtual Event Republic of Korea, 39–44. https://doi.org/10.1145/3463676.3485614
[89] Potential. 2023. Large Scale Pilot (LSP) - Potential - For European Digital Identity. https://www.digital-identity-wallet.eu/
[90] Raül Ramos Fernández. 2024. Evaluation of trust service and software product regimes for zero-knowledge proof development under eIDAS 2.0. *Computer Law & Security Review* 53 (July 2024), 105968. https://doi.org/10.1016/j.clsr.2024.105968
[91] Antonio Robles-González, Javier Parra-Arnau, and Jordi Forné. 2020. A LINDDUN-Based framework for privacy threat analysis on identification and authentication processes. *Computers & Security* 94 (July 2020), 101755. https://doi.org/10.1016/j.cose.2020.101755
[92] Phillip Rogaway. 2016. The Moral Character of Cryptographic Work. USENIX Association, Austin, TX.
[93] Michael Rosenberg, Jacob White, Christina Garman, and Ian Miers. 2023. zk-creds: Flexible Anonymous Credentials from zkSNARKs and Existing Identity Infrastructure. In *2023 IEEE Symposium on Security and Privacy (SP)*. IEEE, San Francisco, CA, USA, 790–808. https://doi.org/10.1109/SP46215.2023.10179430
[94] Johannes Sedlmeir, Jasmin Huber, Tom Barbereau, Linda Weigl, and Tamara Roth. 2022. Transition Pathways towards Design Principles of Self-Sovereign Identity. *ICIS Proceedings* (2022). https://aisel.aisnet.org/icis2022/is_implement/is_implement/4
[95] Guttorm Sindre and Andreas L Opdahl. 2001. Templates for misuse case description. In *Proceedings of the 7th International Workshop on Requirements Engineering, Foundation for Software Quality (REFSQ'2001), Switzerland*. 4–5.
[96] Daniel Slamanig. 2025. Privacy-Preserving Authentication: Theory vs. Practice. https://doi.org/10.48550/arXiv.2501.07209 arXiv:2501.07209 [cs].
[97] Christopher Soghoian. 2011. An End to Privacy Theater: Exposing and Discouraging Corporate Disclosure of User Data to the Government. *Minnesota Journal of Law, Science & Technology* 12, 1 (2011), 191–237. https://scholarship.law.umn.edu/mjlst/vol12/iss1/8
[98] Daniel J. Solove. 2005. A Taxonomy of Privacy. https://papers.ssrn.com/abstract=667622
[99] Daniel J Solove. 2013. Privacy Self-Management and the Consent Dilemma. *Harvard Law Review* 126, 7 (2013), 24.
[100] Manu Sporny, Dave Longley, and David Chadwick. 2022. Verifiable Credentials Data Model v1.1. https://www.w3.org/TR/2022/REC-vc-data-model-20220303/
[101] Manu Sporny, Dave Longley, David Chadwick, and Orie Steele. 2024. Verifiable Credentials Data Model v2.0. https://www.w3.org/TR/vc-data-model-2.0/
[102] Oliver Terbu, Daniel Fett, and Brian Campbell. 2024. *SD-JWT-based Verifiable Credentials (SD-JWT VC)*. Internet-Draft draft-ietf-oauth-sd-jwt-vc-08. Internet Engineering Task Force. https://datatracker.ietf.org/doc/draft-ietf-oauth-sd-jwt-vc/08/ Backup Publisher: Internet Engineering Task Force Num Pages: 54.
[103] O. Terbu, T. Lodderstedt, K. Yasuda, and T. Looker. 2024. OpenID for Verifiable Presentations - draft 22. https://openid.net/specs/openid-4-verifiable-presentations-1_0-22.html
[104] Moritz Teuschel, Daniela Pöhn, Michael Grabatin, Felix Dietz, Wolfgang Hommel, and Florian Alt. 2023. 'Don't Annoy Me With Privacy Decisions!' — Designing Privacy-Preserving User Interfaces for SSI Wallets on Smartphones. *IEEE Access* 11 (2023), 131814–131835. https://doi.org/10.1109/ACCESS.2023.3334908 Conference Name: IEEE Access.
[105] Stephen E. Toulmin. 2003. *The Uses of Argument* (2 ed.). Cambridge University Press. https://doi.org/10.1017/CBO9780511840005
[106] DistriNet Research Unit. 2011. Privacy threat trees booklet. https://downloads.linddun.org/linddun-trees/report/v240118/tree.pdf
[107] Fatbardh Veseli, Jetzabel Serna Olvera, Tobias Pulls, and Kai Rannenberg. 2019. Engineering privacy by design: lessons from the design and implementation of an identity wallet platform. In *Proceedings of the 34th ACM/SIGAPP Symposium on Applied Computing*. ACM, Limassol Cyprus, 1475–1483. https://doi.org/10.1145/3297280.3297429
[108] Samuel Wairimu, Leonardo Horn Iwaya, Lothar Fritsch, and Stefan Lindskog. 2024. On the Evaluation of Privacy Impact Assessment and Privacy Risk Assessment Methodologies: A Systematic Literature Review. *IEEE Access* 12 (2024), 19625–19650. https://doi.org/10.1109/ACCESS.2024.3360864
[109] David Wright and Charles Raab. 2014. Privacy principles, risks and harms. *International Review of Law, Computers & Technology* 28, 3 (Sept. 2014), 277–298. https://doi.org/10.1080/13600869.2014.913874
[110] Kim Wuyts, Riccardo Scandariato, and Wouter Joosen. 2014. Empirical evaluation of a privacy-focused threat modeling methodology. *Journal of Systems and Software* 96 (Oct. 2014), 122–138. https://doi.org/10.1016/j.jss.2014.05.075
[111] Shoshana Zuboff. 2015. Big other: Surveillance Capitalism and the Prospects of an Information Civilization. *Journal of Information Technology* 30, 1 (March 2015), 75–89. https://doi.org/10.1057/jit.2015.5

A Abbreviations

AP Attestation Provider
ARF Architecture and Reference Framework
BLE Bluetooth Low Energy
CA Certification Authority
DIW Digital Identity Wallet
EAA Electronic Attestation of Attributes
eID electronic Identification
eIDAS electronic Identification, Authentication and Trust Services
eKYC electronic Know Your Customer
eSIM embedded SIM
EC European Commission
EU European Union
EUDIW EU Digital Identity Wallet
GDPR General Data Protection Regulation
IdM Identity Management
LoA Level of Assurance
LSP Large Scale Pilot
mDL mobile Driver's License
MS Member State
MSO Mobile Security Object
NFC Near-Field Communication
PET Privacy-Enhancing Technology
PID Person Identification Data
PKI Public Key Infrastructure
QEAA Qualified Electronic Attestation of Attributes
QES Qualified Electronic Signature
QTSP Qualified Trust Service Provider
RAT Remote Attestation Procedure
RI Reference Implementation
RP Relying Party
RPAC Relying Party Access Certificate
SIOP Self-Issued OpenID Provider
SLR systematic literature review
SP Service Provider
SSI Self-Sovereign Identity

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

TEE Trusted Execution Environment
TL Trust List
TLS transport layer security
VP Verifiable Presentation
WP Wallet Provider
WU Wallet Unit
WUA Wallet Unit Attestation
WSCA Wallet Secure Cryptographic Application
WSCD Wallet Secure Cryptographic Device
ZKP Zero-Knowledge Proof
TLS Transport Layer Security

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779

Preprint not peer reviewed

B Privacy harms mapping

Solove [98]'s Privacy harm	Solove [98]'s Description	TC1 Linkability of pseudonyms	TC2 Identifiability risk	TC3 Legitimate intervention	TC4 Non-repudiation risk	TC5 Service exclusion risk	TC6 Insufficient data protection	TC7 Detectability risk
Surveillance	*"Surveillance is the watching, listening to, or recording of an individual's activities."*	Collection of pseudo-identifiers during communication, and these are easily correlatable to attributable data (e.g., ($PK_{\boldsymbol{u}}$, WUA, EEA_{revoc_id}, metadata) ↔ QEAA) by RPs or colluding parties.	APs have access to both pseudo-identifiers and attributable data, while RPs may request attributes for legitimate purposes. Whether colluding or not, they can track and record user activity with identified data.	Attestations and communication protocols' metadata correlated pseudo-identifiers, such as public keys, with attributes (e.g., (Q)EAAs). Certified entities may have access to these data.	The collection and correlation of digitally signed data (e.g., EAAs) and transaction logs enable monitoring and tracking of user activities.	Excessive data requests involving attributes (e.g., EAAs) and pseudo-identifiers (e.g., $PK_{\boldsymbol{u}}$).	ARF does not prevent likability, which facilitates monitoring, tracking, and record-keeping of user-related actions.	User sessions cannot remain unobserved due to the use of standard protocols such as OpenID4{VCI, VP} and ISO18013-5, along with the ARF's specific data for verification (e.g., WUA, $PK_{\boldsymbol{u}}$, EAAs).
Aggregation	*"Aggregation involves the combination of various pieces of data about a person, revealing facts that were not known when data was isolated during collection."*	Correlating pseudo-identifiers with attributable data (e.g., ($PK_{\boldsymbol{u}}$, WUA, EEA_{revoc_id}, metadata) ↔ QEAA) by RPs or colluding parties). Profiling of user's activities.	Correlating pseudo-identifiers with attributable data (e.g., ($PK_{\boldsymbol{u}}$, WUA, EEA_{revoc_id}, metadata) ↔ QEAA) by RPs or colluding parties).	Certified bodies may conflict with the use of pseudonyms, by logging activities, abiding by retention periods across multiple sessions, and therefore correlating them with attributes.	Signed data (e.g., EAAs) that contains attributable data could be linked with pseudo-identifiers causing re-identification or user profiling.	RPs may process all user-related data harnessing correlation either internally or colluding with others.	ARF does not ensure unique, random pseudo-identifiers across all sessions. Verification keys, and actions such as PoP, PoA, correlated with attributable data may lead to re-identification.	Authenticated communication involves a series of potentially persistent pseudo-identifiers, such as key pairs, correlated to attributes.
Identification	*"Identification involves linking and/or connecting information to particular individuals, generally linking digital person to person in real space, in so far revealing true information as someone's identity."*	Correlating pseudo-identifiers with attributable data leads to identification. Especially, the use of $PK_{\boldsymbol{u}}$ and SD-JWT hashes for attestation verification.	Correlating attributable data from QEAAs with pseudo-identifiers from internal, auxiliary databases, or colluding parties.	Correlating attributable data from QEAAs with pseudo-identifiers from internal, auxiliary databases, or colluding parties resulting from logging activities.	Signed data (e.g., EAAs) that contains attributable data, or the combination of authenticated actions, such as QES or PoP during authN, may result in re-identification.	User sharing of EAAs may entail identification. Correlating pseudo-identifiers with categorical attributes may also reveal unique identities.	ARF relies on several unique identifiers, such as attributes in EAA, signatures, public keys, and hashes effectively identifying users.	The use of correlatable information, including attributes, may lead to re-identification.
Insecurity	*"Insecurity involves carelessness in protecting stored information from leaks and improper access, which could result in the injury of being placed in a weakened state of being made more vulnerable to a range of future harms."*	The ARFs along legislative measures mandate long-term storing of pseudo-identifiers, attestation and associated communication metadata. Such information may be subject to breaches and exposure.	While pseudonyms may have been used, they can be correlated, potentially leading to breaches or leaks from databases or other logging activities mandated by retention policies.	Indiscriminate government-approved certificates may be issued, resulting in access to user-related PII while inadequately protecting or potentially abusing it.	Users do not have plausible deniability because of the signature scheme used in all actions (e.g., WUA, PoP, PoA, EAAs).	Excessive data requests involving attributes, such as EAAs, PoP, and PoA.	ARF's failure to provide extensive data protection, such as unlinkability or the right to be forgotten because of transaction logs, leads to insecurity.	Monitoring of user actions, and sessions.
Secondary Use	*"Secondary use is the fact using information collected for one purpose for a different purpose without the data subject's consent."*	RPs may log pseudo-identifiers with attributable data, such as EAA, profile the user's activities, or share and use personal data without prior communication.	Authentication may involve pseudonyms that, upon being linked with linkable data, may reveal the user's identity. Colluding parties may exploit such a scenario.	RPs disclose PII to supervisory bodies without user consent resulting in linkability, or identification.	RPs collection and retention of unique identifiers such as verification keys, which can link signed data within multiple sessions.	The purpose of the requested data remains unclear, conflicting with the purpose limitation and data minimization principles.	The ARF does not guarantee purpose limitation, nor does it have technical policies in place to prevent excessive data requests and secondary uses.	
Exclusion	*"Exclusion is a harm that concerns the failure to allow the data subject to know about the data that others have about her and participate in its handling and use."*	RPs may not communicate all the purposes and use of the requested personal data.	RPs may not communicate to users that their data may end up correlated to each other.	RPs disclose PII without user consent resulting in linkability, or identification.	RPs failure to inform users about signed data being correlated and stored for long periods.	Users may not be aware of the extent to which the data requested is being used.	The ARF does not guarantee purpose limitation or address dispute resolution on informed consent disclosures.	RPs' applications side effects revealing user actions.
Breach of Confidentiality	*"Breach of confidentiality is breaking a promise to keep a person's information confidential."*	RPs share the user's PII with third parties or supervisory bodies without user notice or consent.	Colluding parties collaborate to uniquely identify the user.	RPs disclose PII to supervisory bodies without user consent or notice.	RPs disclose signed data (e.g., EAAs, public keys) to others without user consent.	Excessive data requests involving attributes with unclear purpose.	The ARF does not guarantee purpose limitation once attributes are shared, allowing RPs to act arbitrarily.	RPs' failure to notify users of data processing practices resulting in revealing user actions.
Disclosure	*"Disclosure involves the revelation of truthful information about a person that impacts the reputation of the person."*	RPs share user's profiles.	RPs end up identifying the user.	RPs disclose user PII (e.g., (Q)EAAs) to supervisory bodies.	Signed data proves an undeniable fact (e.g., EAAs).	RPs disclose PII with third parties.	The ARF ensures authentic data, which, upon collection and misuse, could harm users.	RPs' applications side effects revealing user actions.
Increased Accessibility	*"Increased accessibility is amplifying the accessibility of information."*	RPs request, log, and store excessive data. RPs share the user's PII with third parties or supervisory bodies.	RPs request, log, and store excessive data, and thus correlate attributable data (e.g., EAAs). They may share the user's PII with third parties or supervisory bodies.	RPs facilitate the user's PII with third parties or supervisory bodies by logging and retaining communication details.	Signed data is easier to discern than the non-attributable data.	Transaction logs may store excessive data related to users.	The ARF does not limit the amount or form of data that can be collected and stored.	ARF failure to provide unobserved communication may reveal user use of the wallet.
Appropriation	*"Appropriation involves the use of the data subject's identity to serve the aims and interests of another."*				Signed data is non-repudiable and verifiable, which could be misused for impersonation.		The ARF ensures authentic, signed data, which could cause impersonation due to the lack of technical specifications enabling random and uncorrelated user sessions and actions.	
Intrusion	*"Intrusion concerns invasive acts that disturb one's tranquility, solitude, or daily activities, making one feel uneasy."*	RPs collecting and storing data-related actions (as in constant monitoring or surveillance).	RPs collecting and storing data-related actions with unique user identifiers (e.g., $PK_{\boldsymbol{u}}$, EAAs).	Supervisory bodies request access to relying parties' stored information regarding user data-related actions.	RPs collecting and storing signed data.	RPs collecting and storing excessive data.	ARF does not prevent data collection, data retention, or data sharing without user consent.	Monitoring of user actions.
Decisional Interference	*"Decisional interference involves the government's incursion into the data subject's decisions regarding her private affairs."*	Supervisory bodies request access to relying parties' information about users.	Supervisory bodies request access to attributable data (e.g., EAAs) stored by relying parties.	Supervisory bodies request access to attributable data (e.g., EAAs) stored by relying parties.	Supervisory bodies request access to transaction logs regarding users containing signed data.	Supervisory bodies request access to transaction logs regarding users' PII.	ARF does not present policies in place that prevent unauthorized access to user-related data.	Surveillance of user actions.

Table 3: Detailed description for privacy harms mapping to threat cases.

C High-Level overview of EUDIW

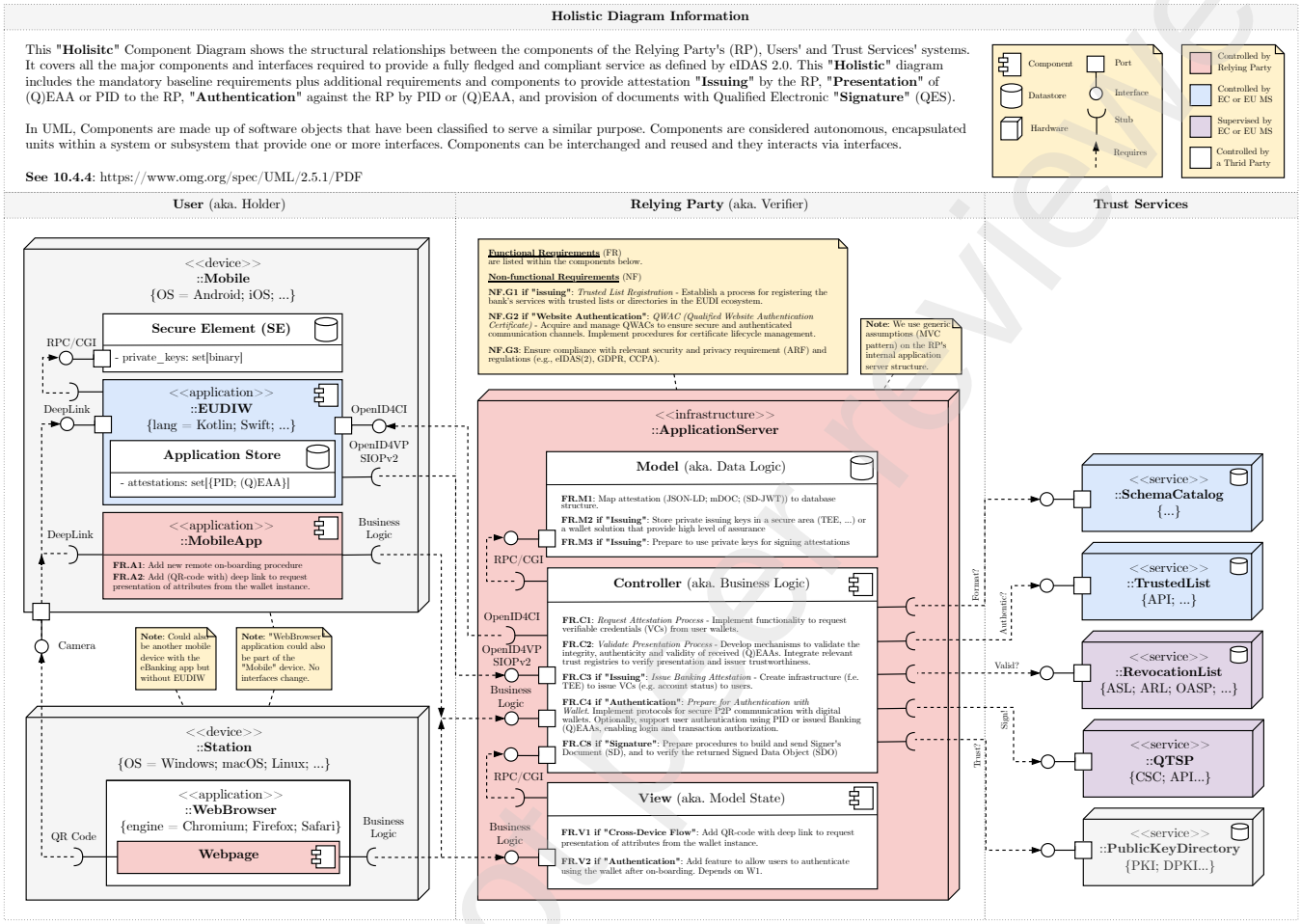


Figure 4: High-level overview of EUDIW's components, services, and protocols from the viewpoint of a relying party.

Preprint not peer reviewed

This preprint research paper has not been peer reviewed. Electronic copy available at: https://ssrn.com/abstract=5248779